Rapport : Mise en place d’une architecture DMZ via GNS3 et Docker

Membres du groupe :

- 1979
- 2075

Table des matieres :

- Rapport : Mise en place d’une architecture DMZ via GNS3 et Docker
  - Membres du groupe :
  - Table des matieres :
  - Introduction
  - Méthodologie
    - **Environnement**
    - 1. **Création des images Docker**
      - 1.1 Client LAN (`ubuntu_client`)
      - 1.2 Pare-feu (`ubuntu_firewall`)
      - 1.3 Serveur Web DMZ (`ubuntu_webserver`)
      - 1.4 Serveur Web LAN (`ubuntu_lan_webserver`)
      - 1.5 WAN (`ubuntu_wan`)
    - 2. **Mise en place de la topologie**
      - 2.1 **Création des containers dockers dans gns3**
        - firewall
        - public-server
        - internal-server
        - internal-desktop
        - internet
      - 2.2 **Mise en place de la topologie dans gns3**
        - 1. Instanciation et liaison des containers
          - Image de la liaison des noeuds :
        - 2. Démarrage et configuration des adresses IP
          - a) LAN
          - b) WAN
          - c) DMZ
          - d) Pare-feu
          - Subnets utilisés
          - Image de la topologie :
      - 3. Configuration des servers
        - 3.1 public-server
        - 3.2 internal-server
        - 3.3 internet
    - 3. **Configuration des services et comportements attendus**
      - 3.1. **Pare-feu**

- - Autoriser HTTP, HTTPS, SSH vers la DMZ (depuis WAN et LAN)
- - Bloquer tout autre port ou protocole par défaut
- - Bloquer l'accès du WAN vers le LAN
- - Autoriser le LAN à sortir vers l'extérieur via NAT
- - Mise en place d'un serveur DNS (Dnsmasq)
  - 1. Configuration de Dnsmasq
  - 2. Ajout d'entrées DNS locales
  - 3. Démarrage du service
  - 4. Configuration des clients DNS
  - 5. Test de la résolution DNS
- - Bloquer les sites pornographiques (SquidGuard)
  - 1. Création d'un fichier de configuration personnalisé pour Squid
  - 2. Configuration de SquidGuard
  - 3. Création de la liste noire
  - 4. Redirection du trafic avec iptables
  - 5. Finalisation de la configuration
  - 5.1 Vérification de la configuration
  - 5.2 Vérification de SquidGuard
  - 6. Test du filtrage
- - Bloquer les réseaux sociaux pendant les heures de travail
  - 1. Mise à jour de la configuration de SquidGuard
  - 2. Création de la liste noire des réseaux sociaux
  - 3. Finalisation et Test
- - Limiter la bande passante avec iptables
  - 1. Application de la limitation de bande passante
  - 2. Vérification et Test
- 3.2. **DMZ**
- 3.3. **Surveillance IDS avec Snort**
  - Detecter et journaliser les tentatives d'attaque et de scan
    - 1. Configuration de base de Snort
    - 2. Modification des variables réseau
    - 3. Création de règles de détection personnalisées
    - 4. Configuration de la journalisation
    - 5. Démarrage de Snort avec la nouvelle configuration

- Résultats des tests
  - Connectivité et isolation des réseaux
  - Filtrage de contenu
  - Qualité de service et limitation de bande passante
  - Détection d'intrusion
- Analyse et conclusion
  - Réalisation des objectifs
  - Difficultés rencontrées
  - Conclusion

Introduction

L'objectif de ce travail pratique est de mettre en œuvre une architecture réseau sécurisée intégrant une zone démilitarisée (DMZ), en utilisant les outils GNS3 et Docker. Ce projet s'inscrit dans le cadre de l'apprentissage des techniques de défense périmétrique d'un système d'information. Il permet de concevoir, configurer et analyser une topologie réseau complète, comprenant la mise en place d'une DMZ, la gestion des règles de filtrage et de NAT, le déploiement de solutions de détection/prévention d'intrusion ainsi que l'analyse des logs pour valider la politique de sécurité. À travers la réalisation de ce TP, les compétences en conception d'architectures sécurisées, en administration réseau et en cybersécurité seront renforcées.

Méthodologie

Environnement

- Ubuntu 24.04 Lts sous WSL 2.5.9
- Docker 28.3.3
- GN3 2.2.54

La méthodologie suivie pour la réalisation de ce travail pratique s'articule autour des étapes suivantes

1. **Création des images Docker**

La première étape a consisté à créer les images Docker nécessaires pour simuler l'ensemble des machines de notre architecture DMZ. Plusieurs Dockerfiles ont été développés, chacun correspondant à un rôle spécifique dans l'infrastructure :

1.1 Client LAN (`ubuntu_client`)

Cette image simule une machine cliente dans le réseau LAN interne de l'entreprise :

```
FROM ubuntu:20.04

ENV DEBIAN_FRONTEND=noninteractive

RUN apt-get update && apt-get install -y \
    lynx \
    iputils-ping \
    traceroute \
    curl \
    wget \
    nano \
    openssh-client \
    iproute2 \
    dnsutils
```

Rôle : Machine cliente utilisée pour tester l'accès depuis le LAN vers la DMZ et Internet, et valider les règles de filtrage du pare-feu.

1.2 Pare-feu (`ubuntu_firewall`)

Cette image centralise toutes les fonctions de sécurité réseau :

```
FROM ubuntu:20.04

ENV DEBIAN_FRONTEND=noninteractive

RUN apt-get update && apt-get install -y \
    iptables \
    iproute2 \
    tcpdump \
    squid \
    squidguard \
    squid-cgi \
    apache2-utils \
    dnsutils \
    dnsmasq \
    iputils-ping \
    curl \
    wget \
    nano \
    iftop \
    tcptrack \
    wondershaper \
    cron
```

Rôle : Pare-feu principal avec filtrage de paquets (iptables), proxy web (Squid), filtrage de contenu (SquidGuard) et outils de monitoring réseau.

1.3 Serveur Web DMZ (`ubuntu_webserver`)

Cette image héberge le serveur web situé dans la DMZ et intègre des outils de supervision et de sécurité :

```
FROM ubuntu:20.04

ENV DEBIAN_FRONTEND=noninteractive

RUN apt-get update && apt-get install -y \
    apache2 \
    lynx \
    iputils-ping \
    traceroute \
    curl \
    wget \
    nano \
    openssh-client \
    openssh-server \
    iproute2 \
    dnsutils \
    apache2-utils \
    tcpdump \
    net-tools \
    snort
```

Rôle : Serveur web Apache situé dans la DMZ, accessible depuis Internet mais isolé du réseau LAN interne. Il intègre également des outils de supervision (`tcpdump`, `net-tools`) et un IDS (`snort`) pour la détection d'intrusions.

1.4 Serveur Web LAN (`ubuntu_lan_webserver`)

Cette image simule un serveur web interne au LAN :

```
FROM ubuntu:20.04

ENV DEBIAN_FRONTEND=noninteractive

RUN apt-get update && apt-get install -y \
    apache2 \
    lynx \
    iputils-ping \
    traceroute \
    curl \
    wget \
    nano \
    openssh-client \
    iproute2 \
    dnsutils \
    apache2-utils
```

Rôle : Serveur web interne au LAN, utilisé pour tester l'accès et l'isolation entre le LAN et la DMZ/WAN.

1.5 WAN (`ubuntu_wan`)

Cette image simule une machine externe sur Internet :

```
FROM ubuntu:20.04

ENV DEBIAN_FRONTEND=noninteractive

RUN apt-get update && apt-get install -y \
    hping3 \
    lynx \
    iputils-ping \
    traceroute \
    curl \
    wget \
    nano \
    openssh-client \
    iproute2 \
    apache2 \
    dnsutils \
    tcpdump
```

Rôle : Machine externe utilisée pour simuler des connexions depuis Internet et tester les règles de sécurité.

Toutes ces images utilisent Ubuntu 20.04 comme base et incluent la variable d'environnement `DEBIAN_FRONTEND=noninteractive` pour automatiser l'installation des paquets sans interaction utilisateur.

2. **Mise en place de la topologie**

2.1 Création des containers dockers dans gns3

firewall

- docker image : ubuntu_firewall
- interfaces : 3
- console : telnet

public-server

- docker image : ubuntu_webserver
- interfaces : 1
- console : telnet

internal-server

- docker image : ubuntu_lan_webserver
- interfaces : 1
- console : telnet

internal-desktop

- docker image : ubuntu_client
- interfaces : 1
- console : telnet

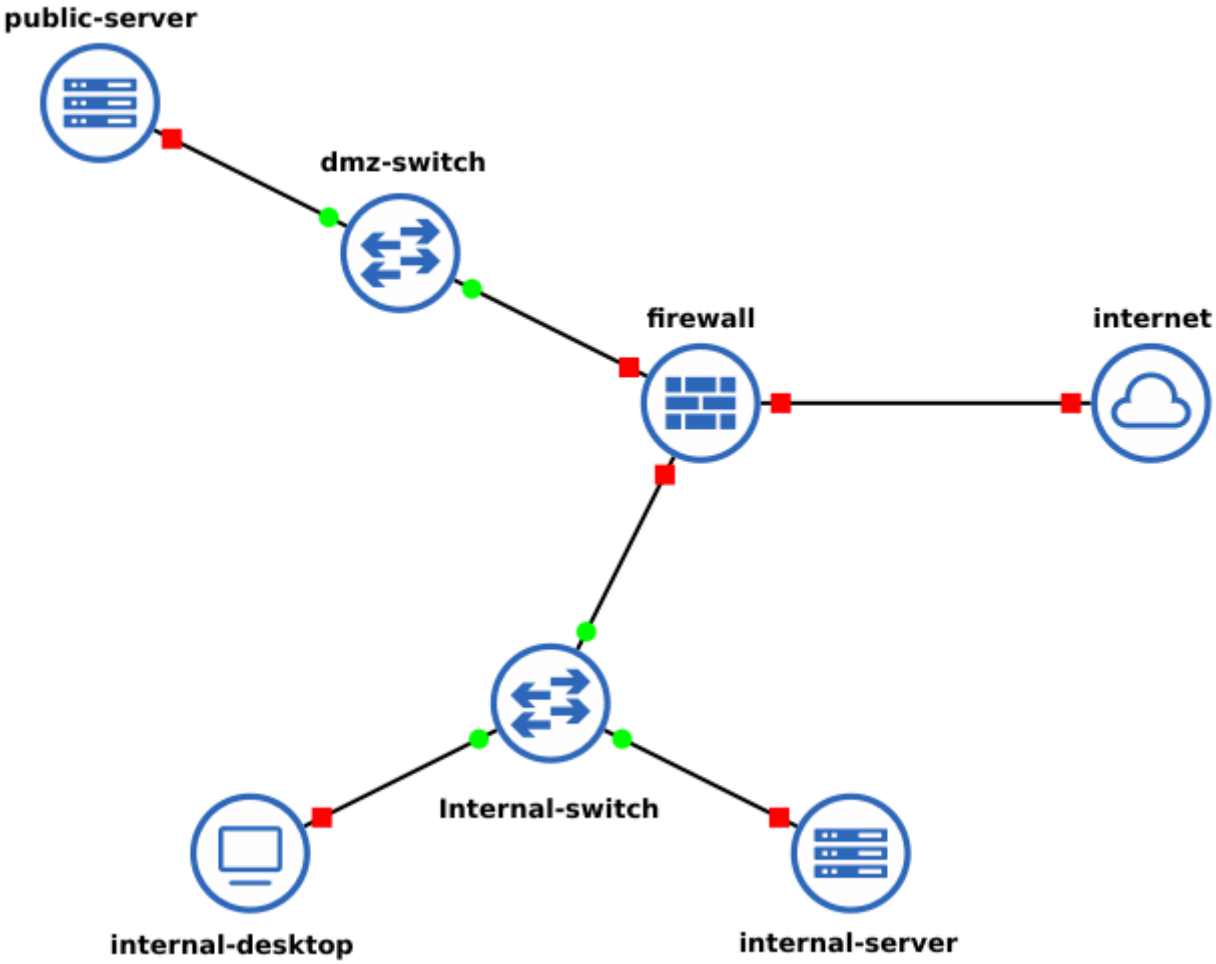
internet

- docker image : ubuntu_wan
- interfaces : 1
- console : telnet

2.2 Mise en place de la topologie dans gns3

1. Instanciation et liaison des containers

On commence par instancier les containers et les relier comme dans la figure ci-dessous :



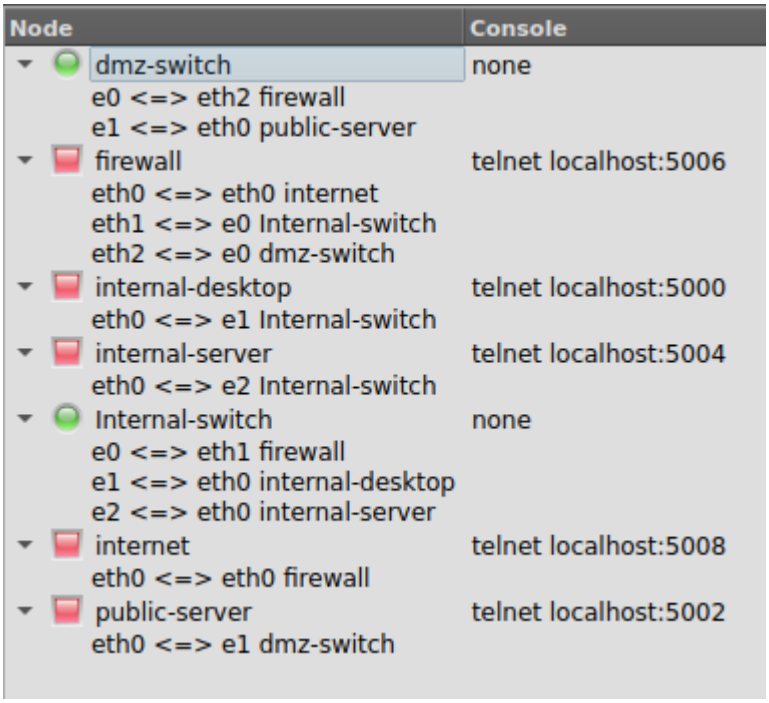
Structure réseau :

- **dmz-switch**
  - e0 ←→ eth2 firewall
  - e1 ←→ eth0 public-server
- **firewall**
  - eth0 ←→ e0 internal-switch
  - eth1 ←→ e0 internal-switch
  - eth2 ←→ e1 dmz-switch
- **internal-desktop**
  - eth0 ←→ e1 internal-switch
- **internal-server**
  - eth0 ←→ e2 internal-switch
- **internal-switch**
  - e0 ←→ eth1 firewall
  - e1 ←→ eth0 internal-desktop

    - e2 ←→ eth0 internal-server

- **internet**
    - eth0 ←→ eth0 firewall
- **public-server**
    - eth0 ←→ e1 dmz-switch

Image de la liaison des noeuds :



2. Démarrage et configuration des adresses IP

Après le démarrage de toutes les instances, on configure leurs adresses IP comme suit :

a) LAN

- **internal-desktop**

```
ip a add 19.4.3.1/29 dev eth0
ip route add default via 19.4.3.3 dev eth0
echo "nameserver 19.4.3.3" > /etc/resolv.conf
```

- **internal-server**

```
ip a add 19.4.3.2/29 dev eth0
ip route add default via 19.4.3.3 dev eth0
echo "nameserver 19.4.3.3" > /etc/resolv.conf
```

b) WAN

- **internet**

```
ip a add 19.4.3.17/29 dev eth0
ip route add default via 19.4.3.18 dev eth0
```

c) DMZ

- **public-server (DMZ)**

```
ip a add 19.4.3.9/29 dev eth0
ip route add default via 19.4.3.11 dev eth0
```

d) Pare-feu

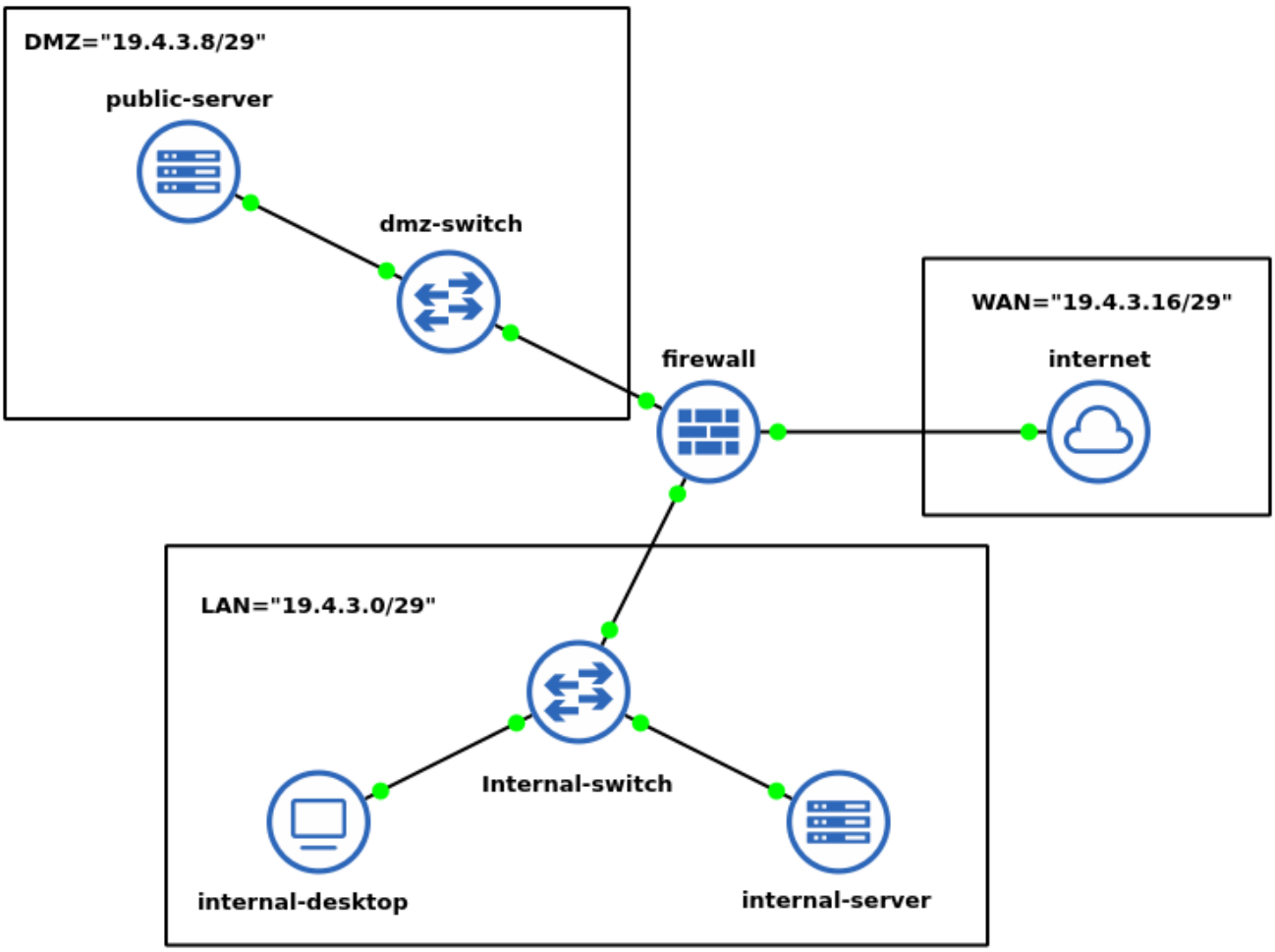
- **firewall**

```
ip a add 19.4.3.3/29 dev eth1
ip a add 19.4.3.11/29 dev eth2
ip a add 19.4.3.18/29 dev eth0
sysctl -w net.ipv4.ip_forward=1
```

Subnets utilisés

```
WAN="19.4.3.16/29"
LAN="19.4.3.0/29"
DMZ="19.4.3.8/29"
```

Image de la topologie :



3. Configuration des servers

3.1 public-server

```
echo "ServerName localhost" | tee /etc/apache2/conf-available/servername.conf
a2enconf servername
service apache2 restart

cd /var/www/html/

echo "<html>
<head>
   <title>Serveur Apache dans Docker DMZ</title>
</head>
<body>
   <h1>Bienvenue sur le serveur publique</h1>
</body>
</html>" > /var/www/html/index.html

a2enmod ssl
a2enmod rewrite

mkdir -p /etc/ssl/private
```

```
mkdir -p /etc/ssl/certs

openssl req -x509 -nodes -days 365 -newkey rsa:2048 \
   -keyout /etc/ssl/private/apache-selfsigned.key \
   -out /etc/ssl/certs/apache-selfsigned.crt \
   -subj "/C=FR/ST=State/L=City/O=Organization/OU=OrgUnit/CN=webserver"

cat > /etc/apache2/sites-available/default-ssl.conf << 'EOF'
<IfModule mod_ssl.c>
   <VirtualHost *:443>
       DocumentRoot /var/www/html

       SSLEngine on
       SSLCertificateFile /etc/ssl/certs/apache-selfsigned.crt
       SSLCertificateKeyFile /etc/ssl/private/apache-selfsigned.key

       <FilesMatch "\.(cgi|shtml|phtml|php)$">
           SSLOptions +StdEnvVars
       </FilesMatch>
   </VirtualHost>
</IfModule>
EOF

a2ensite default-ssl

service apache2 restart

mkdir -p /var/run/sshd
ssh-keygen -A
echo "PasswordAuthentication yes" >> /etc/ssh/sshd_config
echo "PermitRootLogin yes" >> /etc/ssh/sshd_config
useradd -m -s /bin/bash user
echo "user:root" | chpasswd
service ssh start
```

3.2 internal-server

```
 echo "ServerName localhost" | tee /etc/apache2/conf-available/servername.conf
 a2enconf servername
 service apache2 restart

 cd /var/www/html/

 echo "<html>
 <head>
     <title>Serveur Apache dans Docker Interne</title>
 </head>
 <body>
     <h1>Bienvenue sur le serveur interne</h1>
 </body>
```

```
</html>" > /var/www/html/index.html
```

3.3 internet

```
echo "ServerName localhost" | tee /etc/apache2/conf-available/servername.conf
a2enconf servername
service apache2 restart

cd /var/www/html/

echo "<html>
<head>
    <title>Mon serveur Apache dans Docker du WAN</title>
</head>
<body>
    <h1>Bienvenue sur le WAN</h1>
</body>
</html>" > /var/www/html/index.html
```

3. **Configuration des services et comportements attendus**

3.1. Pare-feu

On definit tout d'abord les varables à utiliser :

```
WAN="19.4.3.16/29"
LAN="19.4.3.0/29"
DMZ="19.4.3.8/29"
HTTP="80"
HTTPS="443"
SSH="22"

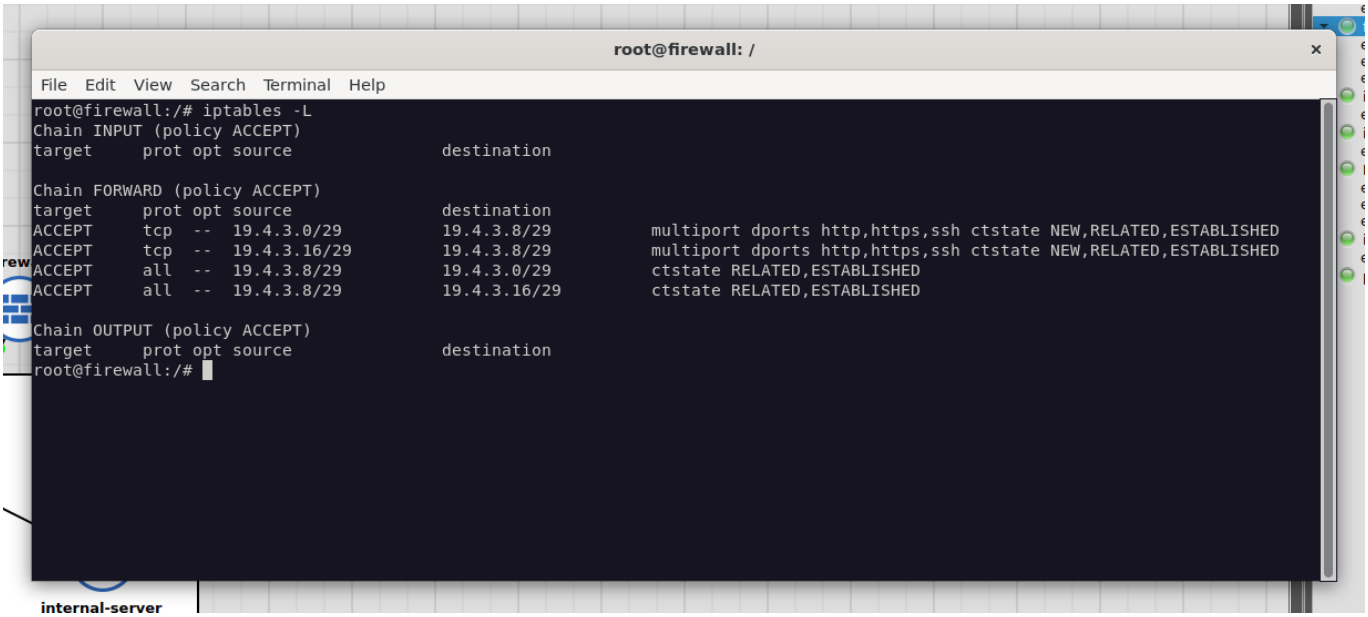
WAN_IFACE="eth0"
LAN_IFACE="eth1"
DMZ_IFACE="eth2"
```

Etant donné qu'on a crée l'image docker à partir d'une image **ubuntu vierge** et qu'on a **nous meme installé les packets necessaires**, `iptables` **ne contient encore aucune regle**.

- Autoriser HTTP, HTTPS, SSH vers la DMZ (depuis WAN et LAN)

```
iptables -A FORWARD -p tcp -s $LAN,$WAN -d $DMZ -m multiport --dports
$HTTP,$HTTPS,$SSH -m conntrack --ctstate NEW,ESTABLISHED,RELATED -j ACCEPT
```

```
 iptables -A FORWARD -s $DMZ -d $LAN,$WAN -m conntrack --ctstate
ESTABLISHED,RELATED -j ACCEPT
```

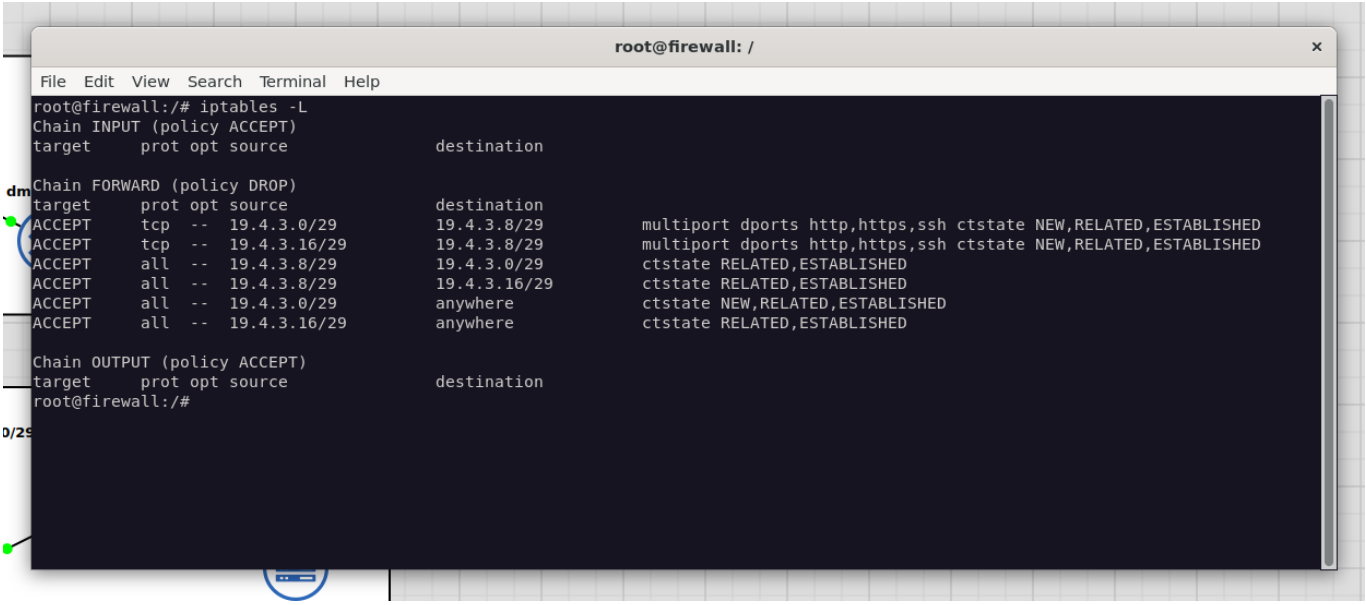


Justification :

1. Première règle (`iptables -A FORWARD -p tcp -s $LAN,$WAN -d $DMZ...`) :
    - `-A FORWARD` ajoute la règle à la chaîne FORWARD qui traite les paquets routés entre interfaces
    - `-p tcp` filtre uniquement le protocole TCP
    - `-s $LAN,$WAN` spécifie les sources autorisées (réseau local et Internet)
    - `-d $DMZ` cible uniquement les paquets à destination de la DMZ
    - `-m multiport --dports $HTTP,$HTTPS,$SSH` utilise le module multiport pour spécifier efficacement plusieurs ports de destination (80, 443, 22)
    - `-m conntrack --ctstate NEW,ESTABLISHED,RELATED` active le module de suivi de connexion et autorise : les nouvelles connexions (NEW), les paquets appartenant à une connexion déjà établie (ESTABLISHED), et les paquets liés à une connexion existante comme dans le FTP passif (RELATED)
    - `-j ACCEPT` applique l'action d'acceptation pour les paquets correspondant à tous les critères ci-dessus
2. Seconde règle (`iptables -A FORWARD -s $DMZ -d $LAN,$WAN...`) :
    - Cette règle complémentaire autorise uniquement les réponses depuis la DMZ vers le LAN ou le WAN
    - L'absence de l'état `NEW` dans `--ctstate` est cruciale : elle empêche les serveurs de la DMZ d'initier des connexions vers l'intérieur ou l'extérieur, limitant ainsi la portée d'une éventuelle compromission

- Bloquer tout autre port ou protocole par défaut

```
iptables -P FORWARD DROP
```



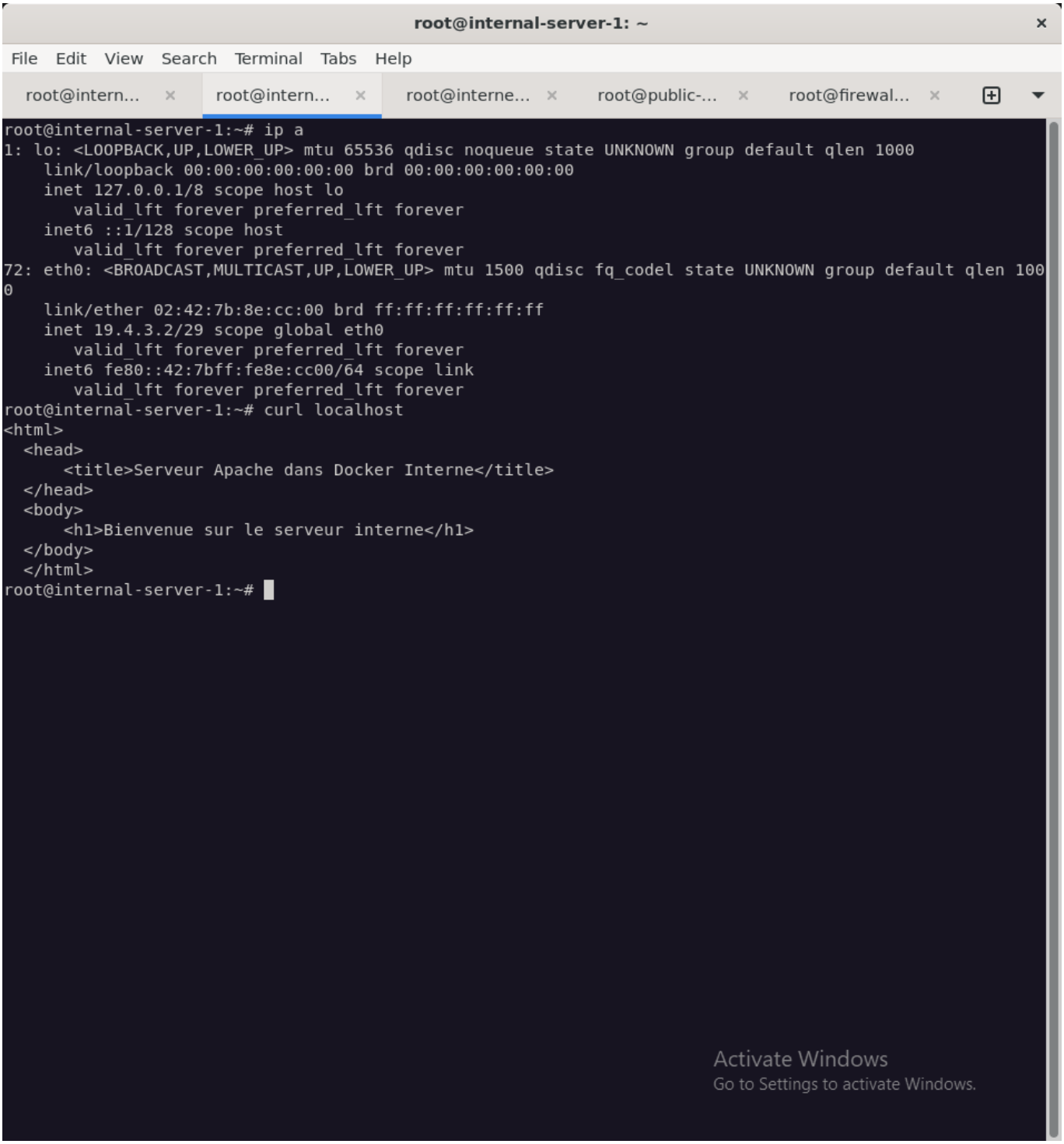
Justification : Cette règle applique une politique de sécurité par défaut restrictive (deny-by-default), un principe fondamental dans la conception de pare-feu. En bloquant tout trafic non explicitement autorisé, nous réduisons considérablement la surface d'attaque. Cette approche est essentielle car elle garantit que seules les connexions précédemment définies comme légitimes sont autorisées à traverser le pare-feu, tandis que toute tentative d'exploitation de services non autorisés est automatiquement bloquée. Cela nous protège également contre les risques liés aux services qui pourraient être activés par erreur ou aux nouvelles vulnérabilités découvertes sur des ports non surveillés.

- Bloquer l’accès du WAN vers le LAN

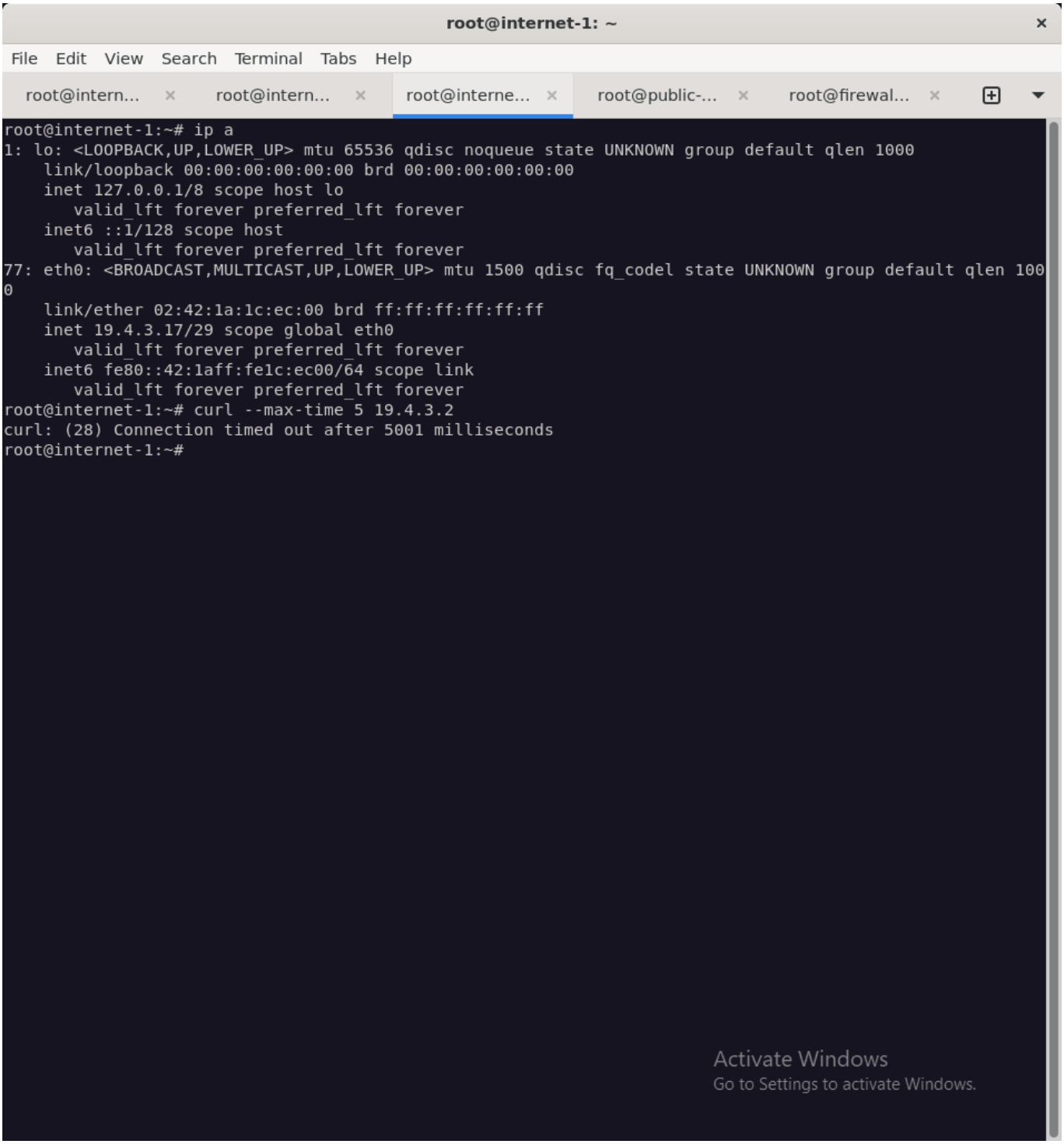
Déja inclut avec :

```
iptables -P FORWARD DROP
```

curl du server LAN local vers lui meme :

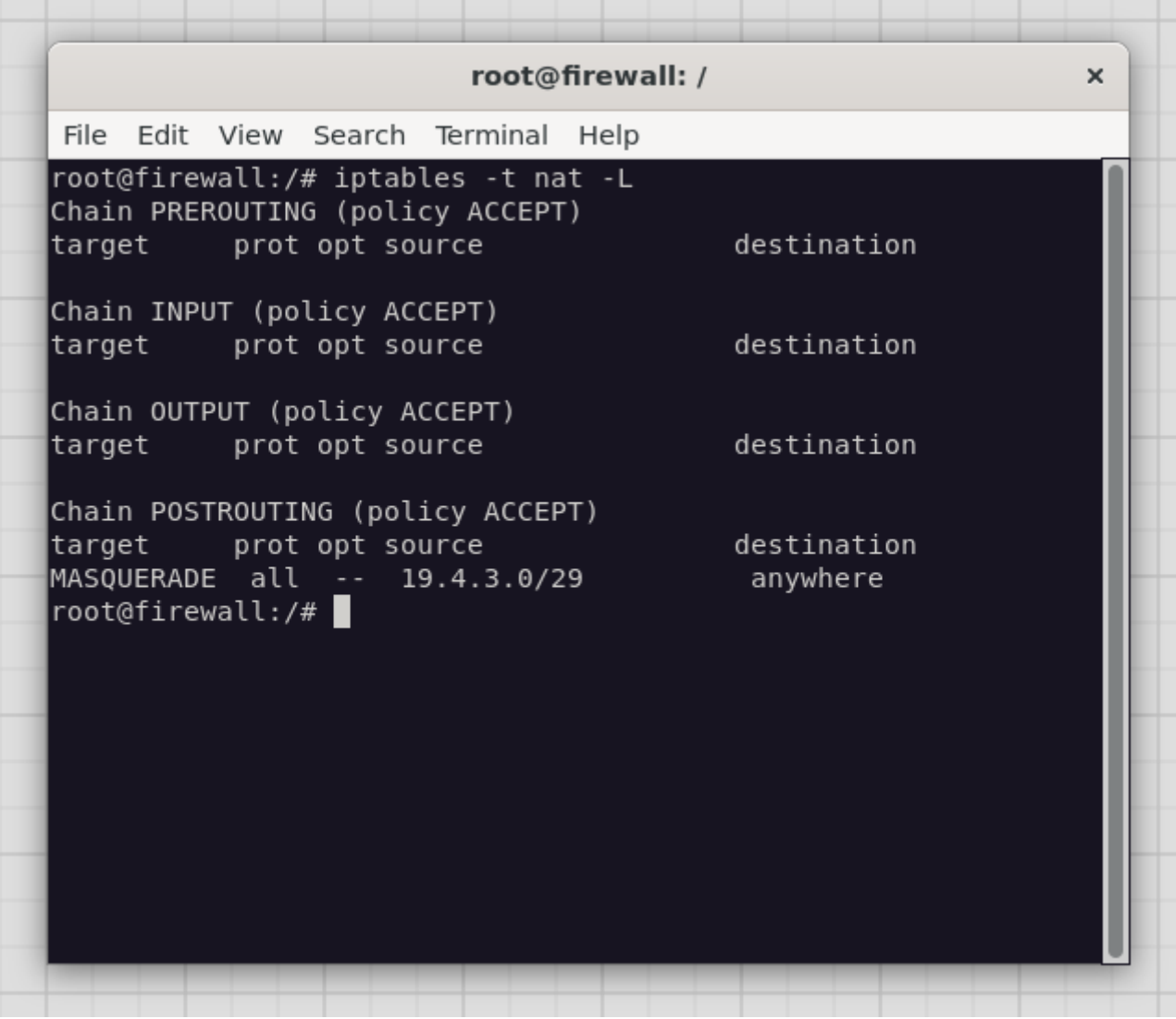


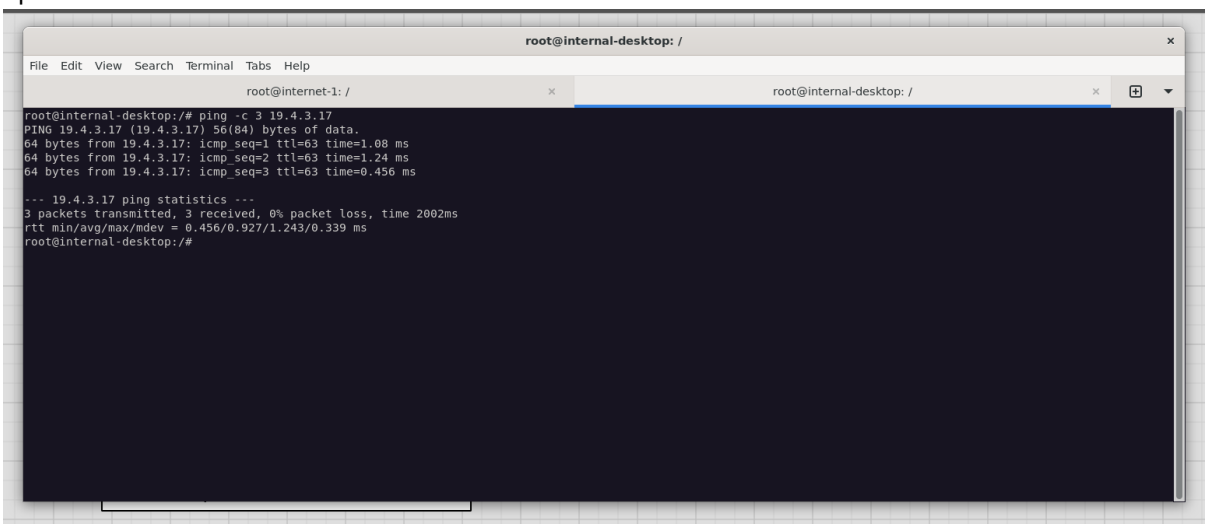
curl depuis le WAN vers me server LAN local :



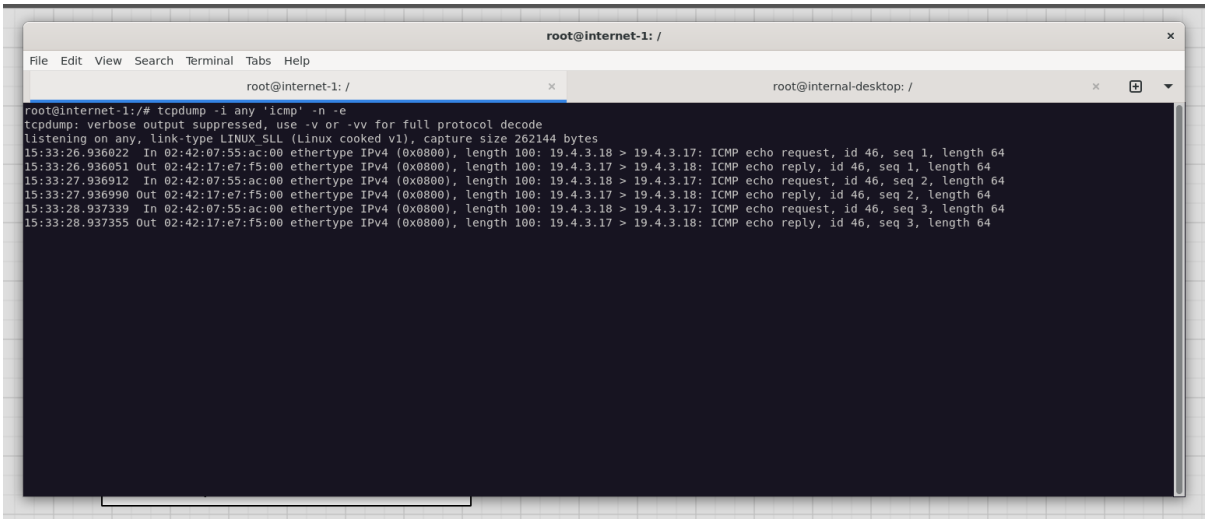
- Autoriser le LAN à sortir vers l'extérieur via NAT

```
 iptables -t nat -A POSTROUTING -s $LAN -o $WAN_IFACE -j MASQUERADE
 iptables -A FORWARD -s $LAN -o $WAN_IFACE -m conntrack --ctstate
NEW,ESTABLISHED,RELATED -j ACCEPT
 iptables -A FORWARD -s $WAN -i $WAN_IFACE -m conntrack --ctstate
ESTABLISHED,RELATED -j ACCEPT
```



- ping depuis LAN vers WAN :
  - 

- affichage des packets dans internet :



Justification : Ces trois règles fonctionnent ensemble pour permettre la communication du réseau LAN vers l'extérieur tout en maintenant la sécurité :

1. La première règle (`MASQUERADE`) agit sur la table NAT et manipule les paquets sortants. Elle remplace l'adresse IP source des paquets provenant du LAN par l'adresse IP publique du pare-feu sur son interface WAN. Cette substitution permet aux machines du LAN (qui utilisent des adresses privées) de communiquer avec Internet.
2. La deuxième règle autorise le transfert des paquets du LAN vers le WAN. L'option `--ctstate NEW,ESTABLISHED,RELATED` est cruciale : elle permet aux machines du LAN d'initier de nouvelles connexions (`NEW`) et de maintenir les connexions déjà établies (`ESTABLISHED`) ou liées à une connexion existante (`RELATED`).
3. La troisième règle permet le retour des paquets de réponse depuis le WAN vers le LAN, mais uniquement pour des connexions déjà établies ou associées (`ESTABLISHED,RELATED`). Cette restriction empêche l'initiation de connexions depuis l'extérieur, renforçant ainsi la sécurité du réseau interne.

- Mise en place d'un serveur DNS (Dnsmasq)

Pour simplifier la résolution de noms dans notre topologie, nous allons configurer `dnsmasq` sur le pare-feu. Ce service agira comme un serveur DNS pour le LAN, résolvant les noms de domaine de notre réseau local et transférant les autres requêtes à des serveurs DNS externes (simulés ou réels).

Justification : L'implémentation d'un serveur DNS local avec Dnsmasq sur notre pare-feu etant donné que notre environnement ne dispose pas d'access à internet et donc on ne peut pas utiliser les DNS standards comme ceux de google ou cloudflare.

1. Configuration de Dnsmasq

Créez un fichier de configuration pour `dnsmasq` sur le pare-feu. Nous allons le configurer pour qu'il écoute uniquement sur l'interface du LAN et utilise le fichier `/etc/hosts` du pare-feu comme source pour les noms locaux.

```
# Sur le pare-feu
cat > /etc/dnsmasq.conf << 'EOF'
interface=eth1
```

```
no-resolv
server=8.8.8.8
expand-hosts
domain=lan.local
EOF
```

2. Ajout d'entrées DNS locales

Pour que notre test de filtrage fonctionne sans modifier le fichier `/etc/hosts` de chaque client, nous pouvons ajouter l'entrée directement dans le fichier `/etc/hosts` du pare-feu. `dnsmasq` le servira ensuite à tout le LAN.

```
# Sur le pare-feu
echo "19.4.3.17 pornhub.com" >> /etc/hosts
```

3. Démarrage du service

```
# Sur le pare-feu
service dnsmasq start
```

4. Configuration des clients DNS

Nous avons déjà mis à jour la configuration des machines du LAN à l'étape 2.2 pour qu'elles utilisent le pare-feu (`19.4.3.3`) comme serveur DNS.

5. Test de la résolution DNS

Depuis `internal-desktop`, vous pouvez maintenant utiliser `nslookup` ou `dig` pour vérifier que la résolution de noms fonctionne.

```
# Sur internal-desktop
nslookup pornhub.com
```

La réponse devrait être `19.4.3.17`.

- Bloquer les sites pornographiques (SquidGuard)

Pour bloquer l'accès à des sites spécifiques, nous utiliserons Squid comme proxy transparent et SquidGuard comme filtre d'URL. Le trafic HTTP du LAN sera redirigé vers Squid, qui le passera à SquidGuard pour inspection.

1. Création d'un fichier de configuration personnalisé pour Squid

Pour éviter les conflits avec la configuration par défaut, nous allons créer un fichier séparé qui contiendra nos directives. Squid lira ce fichier et appliquera nos règles.

Créez le fichier `/etc/squid/conf.d/00-custom.conf` sur le pare-feu :

```
cat >/etc/squid/conf.d/00-custom.conf<< 'EOF'
http_port 3128 intercept

http_port 127.0.0.1:3129

acl localnet src 19.4.3.0/29

http_access allow localnet

url_rewrite_program /usr/bin/squidGuard -c /etc/squidguard/squidGuard.conf

url_rewrite_children 5
EOF
```

2. Configuration de SquidGuard

Créez et configurez le fichier `/etc/squidguard/squidGuard.conf` pour définir les listes de blocage.

```
cat >/etc/squidguard/squidGuard.conf<< 'EOF'
dbhome /var/lib/squidguard/db

logdir /var/log/squid

src lan {
    ip 19.4.3.0/29
}

dest porn {
    domainlist porn/domains
    urllist porn/urls
}

acl {
    lan {
        pass !porn all
        redirect http://19.4.3.3/cgi-bin/squidGuard.cgi?
clientaddr=%a&clientname=%n&clientuser=%i&clientgroup=%s&targetgroup=%t&url=%u
    }
    default {
        pass none
        redirect http://19.4.3.3/cgi-bin/squidGuard.cgi?
clientaddr=%a&clientname=%n&clientuser=%i&clientgroup=%s&targetgroup=%t&url=%u
    }
}
EOF
```

3. Création de la liste noire

Nous devons créer les fichiers contenant les domaines et URL à bloquer.

```
mkdir -p /var/lib/squidguard/db/porn

cat > /var/lib/squidguard/db/porn/domains << 'EOF'
pornhub.com
xvideos.com
xnxx.com
redtube.com
youporn.com
EOF

touch /var/lib/squidguard/db/porn/urls
```

4. Redirection du trafic avec iptables

Ajoutez une règle `iptables` sur le pare-feu pour rediriger tout le trafic HTTP (port 80) provenant du LAN vers le port de Squid (3128).

Rediriger le trafic HTTP du LAN vers Squid

```
iptables -t nat -A PREROUTING -i $LAN_IFACE -p tcp --dport 80 -j REDIRECT --to-
port 3128
```

Justification du fonctionnement de la règle : Cette règle NAT utilise la chaîne `PREROUTING` qui intercepte les paquets avant qu'ils ne soient routés. Le paramètre `-i $LAN_IFACE` spécifie que seul le trafic entrant sur l'interface LAN est concerné. Le filtre `-p tcp --dport 80` cible spécifiquement le trafic HTTP standard. L'action `REDIRECT --to-port 3128` redirige ce trafic vers le port local où Squid écoute, sans que les clients ne soient conscients de cette redirection.

5. Finalisation de la configuration

Compilez la base de données de SquidGuard, ajustez les permissions et redémarrez les services.

```
squidGuard -b -d -C all

chown -R proxy:proxy /var/lib/squidguard/db
chown -R proxy:proxy /var/log/squid
chmod -R 755 /var/lib/squidguard/db

service squid restart
```

5.1 Vérification de la configuration

Avant de redémarrer Squid, il est crucial de vérifier que les fichiers de configuration ne contiennent pas d'erreurs de syntaxe.

```
squid -k parse
```

Si cette commande ne retourne aucune erreur, vous pouvez continuer. Sinon, vous devrez corriger les erreurs indiquées dans `squid.conf` avant de poursuivre.

5.2 Vérification de SquidGuard

Si la configuration de Squid est valide mais que le service ne démarre toujours pas, le problème vient probablement de SquidGuard.

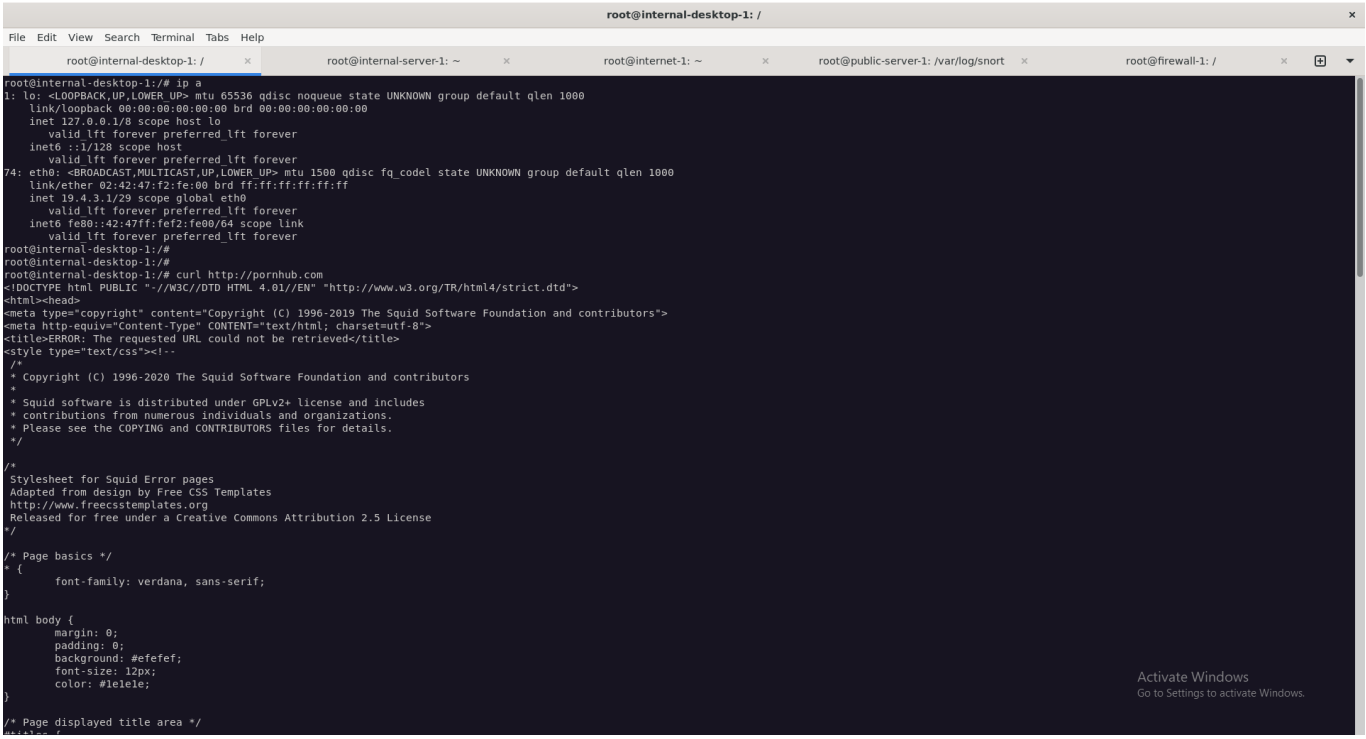
```
chown -R proxy:proxy /var/lib/squidguard/db
chmod -R 755 /var/lib/squidguard/db

squidGuard -b -d -C all
```

6. Test du filtrage

Dans notre topologie simulée, les machines du LAN n'ont pas accès à un serveur DNS public pour résoudre les noms de domaine comme `pornhub.com`. Pour pouvoir tester notre configuration, nous avons deja utilisé `dnsmasq`. Il ne nous reste plus qu'à executer la commande :

```
curl http://pornhub.com
```



- Bloquer les réseaux sociaux pendant les heures de travail

Nous utiliserons la fonctionnalité de gestion du temps de SquidGuard.

1. Mise à jour de la configuration de SquidGuard

Modifiez le fichier `/etc/squidguard/squidGuard.conf` pour y inclure une définition des plages horaires et une nouvelle catégorie de sites à bloquer ("social"). La section `acl` est également mise à jour pour appliquer des règles différentes en fonction de l'heure.

Le nouveau contenu complet du fichier de configuration est le suivant :

```
cat >/etc/squidguard/squidGuard.conf<< 'EOF'
dbhome /var/lib/squidguard/db

logdir /var/log/squid

src lan {
    ip 19.4.3.0/29
}

time workhours {
    weekly mtwhf 08:00-12:00
    weekly mtwhf 14:00-18:00
}

dest porn {
    domainlist porn/domains
    urllist porn/urls
}
```

```
dest social {
    domainlist social/domains
    urllist social/urls
}

acl {
    lan within workhours {
        pass !porn !social all
        redirect http://19.4.3.3/cgi-bin/squidGuard.cgi?
clientaddr=%a&clientname=%n&clientuser=%i&clientgroup=%s&targetgroup=%t&url=%u
    }

    lan {
        pass !porn all
        redirect http://19.4.3.3/cgi-bin/squidGuard.cgi?
clientaddr=%a&clientname=%n&clientuser=%i&clientgroup=%s&targetgroup=%t&url=%u
    }

    default {
        pass none
        redirect http://19.4.3.3/cgi-bin/squidGuard.cgi?
clientaddr=%a&clientname=%n&clientuser=%i&clientgroup=%s&targetgroup=%t&url=%u
    }
}
EOF
```

2. Création de la liste noire des réseaux sociaux

Ajoutez la liste des domaines de réseaux sociaux à bloquer.

Créer le répertoire et la liste pour les réseaux sociaux, lister les domaines et creer le fichier contenant les urls (pour ne pas avoir d'erreur lors de la verofocation du ficher de configuration)

```
mkdir -p /var/lib/squidguard/db/social

cat > /var/lib/squidguard/db/social/domains << 'EOF'
facebook.com
twitter.com
instagram.com
tiktok.com
linkedin.com
snapchat.com
pinterest.com
EOF

touch /var/lib/squidguard/db/social/urls
```

3. Finalisation et Test

Après avoir modifié la configuration et ajouté la nouvelle liste, vous devez recompiler la base de données de SquidGuard et redémarrer le service, comme à l'étape 5.

Compiler la base de données (inclut maintenant la liste "social"), s'assurer que les permissions sont correctes et redemarrer squid

```
squidGuard -b -d -C all

chown -R proxy:proxy /var/lib/squidguard/db
chmod -R 755 /var/lib/squidguard/db

service squid restart
```

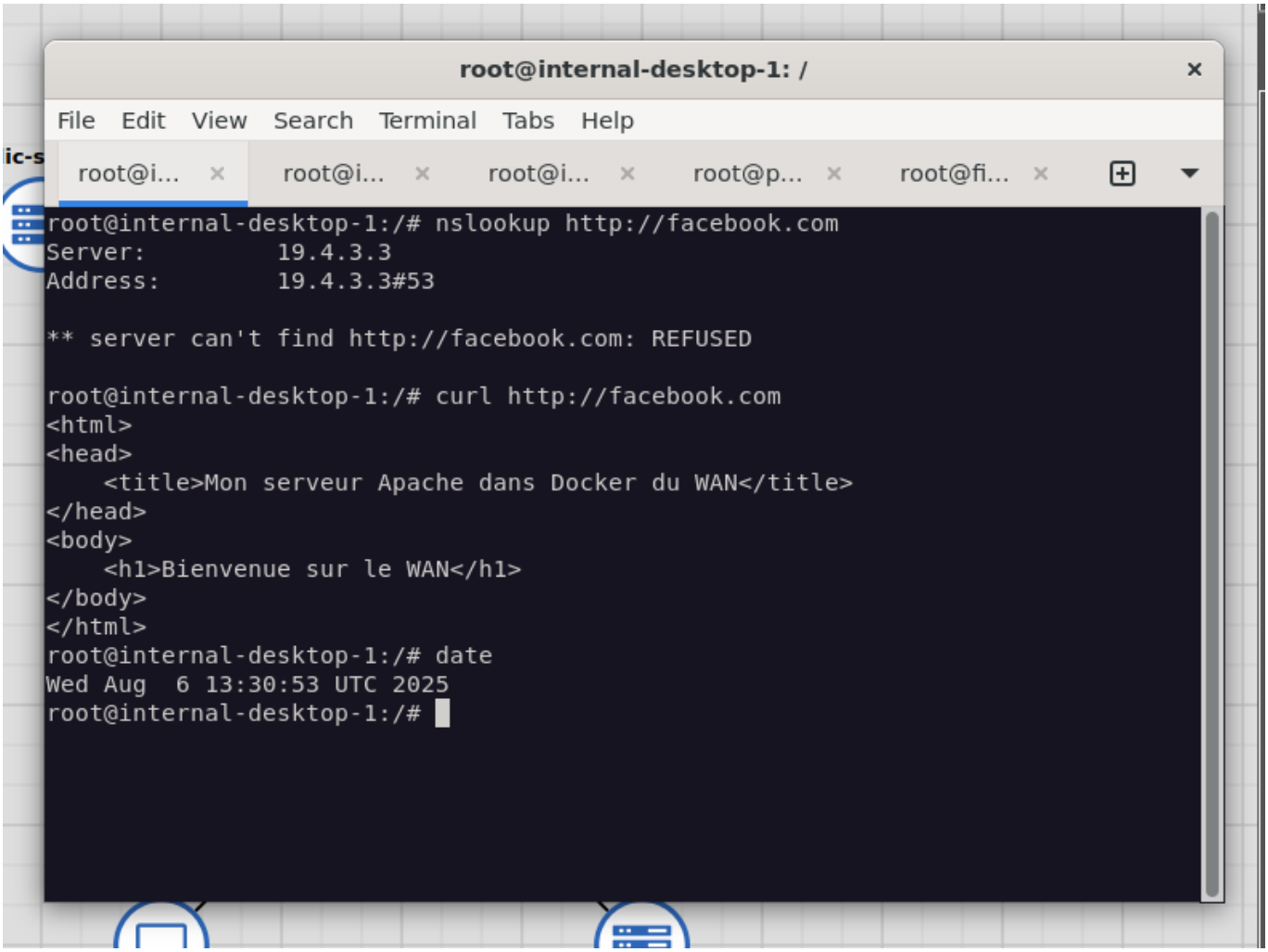
Pour tester, ajoutez les domaines des réseaux sociaux au fichier `/etc/hosts` du pare-feu (pour que `dnsmasq` les résolve), puis essayez d'y accéder depuis `internal-desktop` avec `curl`.

```
# Sur le pare-feu
echo "19.4.3.17 facebook.com" >> /etc/hosts
echo "19.4.3.17 twitter.com" >> /etc/hosts

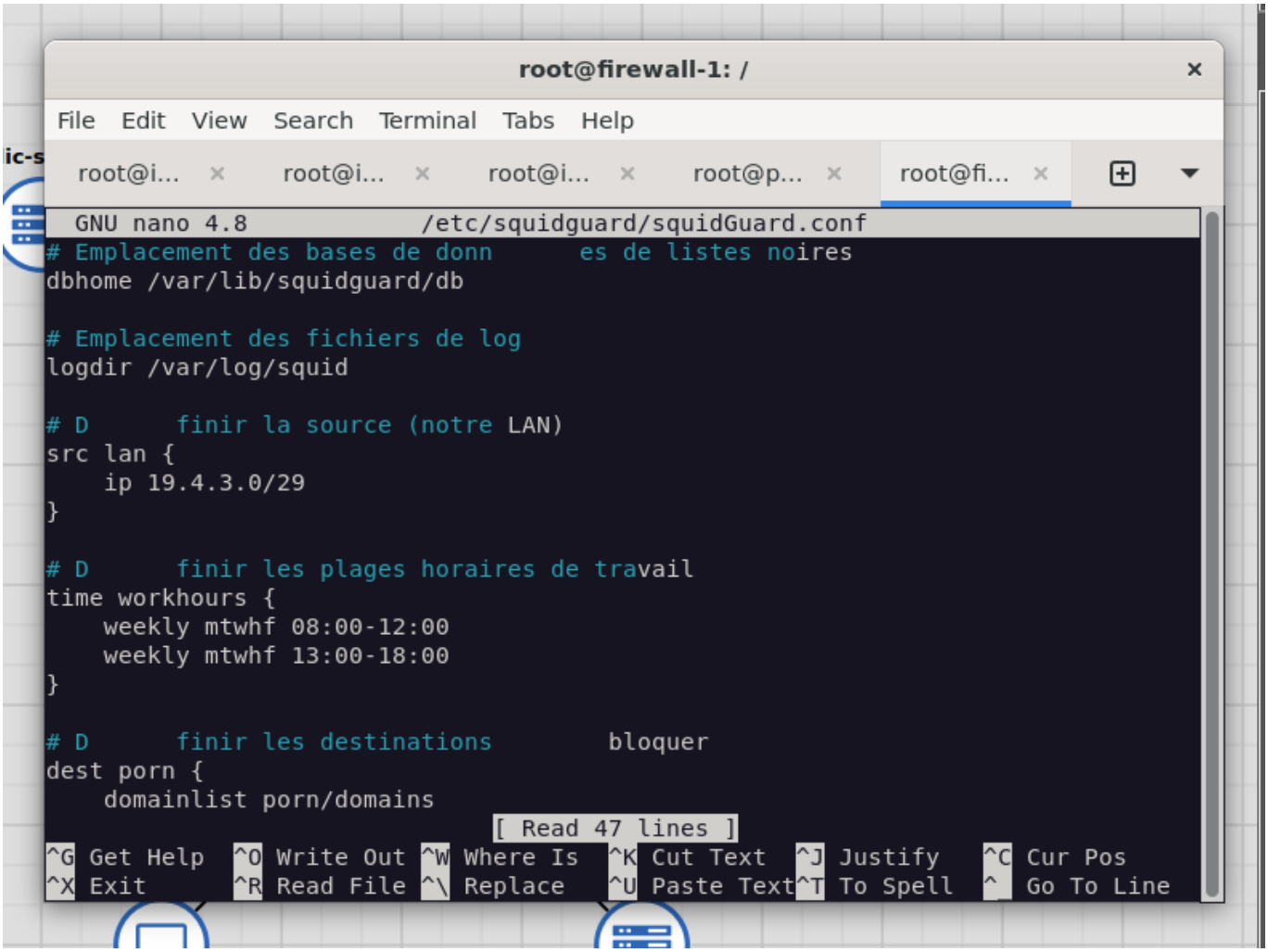
service dnsmasq restart

# Sur internal-desktop, pendant les heures de travail
curl http://facebook.com
```

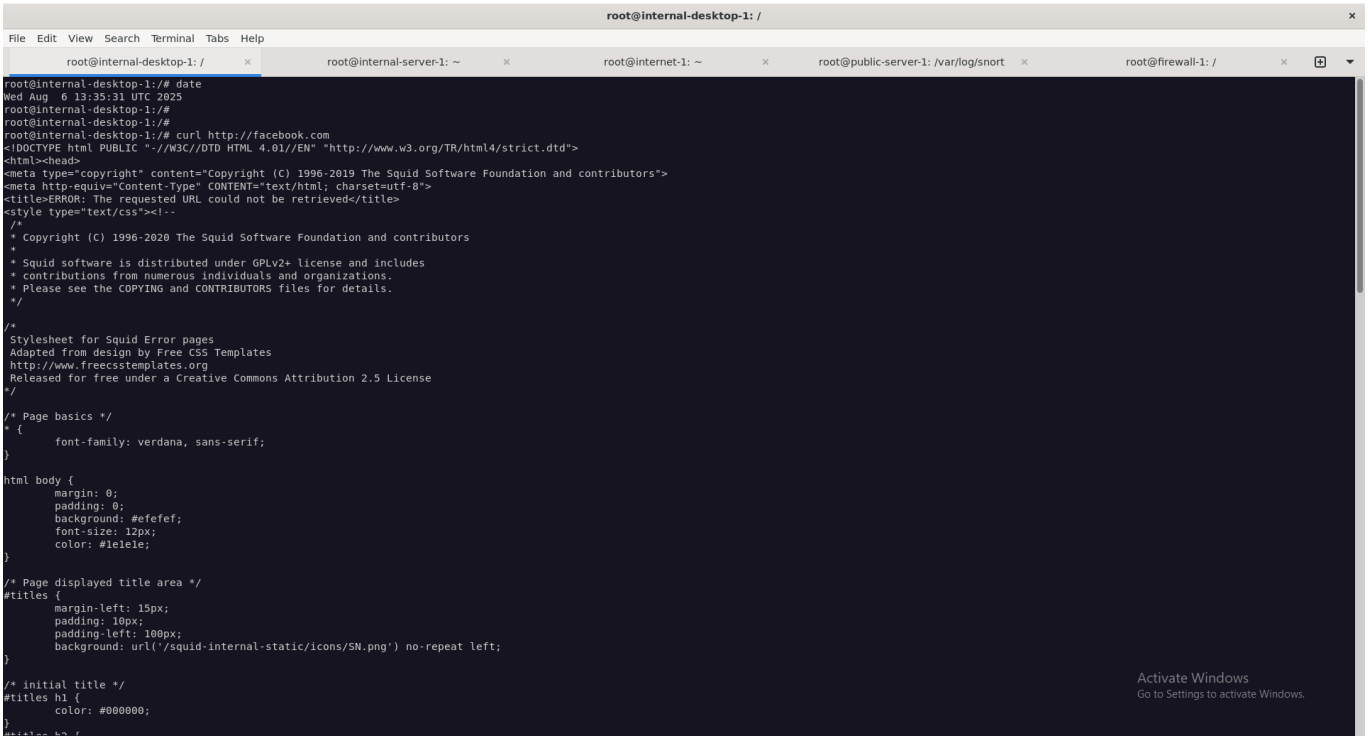
curl depuis le LAN vers facebook à 13h :



configuration de l'heure de travail à 13h pour le test :



curl depuis le LAN vers facebook à durant les heures de travail:



- Limiter la bande passante avec iptables

Pour garantir une utilisation équitable des ressources réseau, nous allons mettre en place une politique de Qualité de Service (QoS) pour limiter la bande passante de chaque machine du LAN à 500 Ko/s. Nous utiliserons le module `hashlimit` d'iptables.

Justification : L'implémentation de limitations de bande passante répond à plusieurs besoins critiques dans un environnement réseau partagé. Premièrement, elle prévient la monopolisation des ressources réseau par un petit nombre d'utilisateurs ou d'applications, garantissant ainsi une distribution équitable de la connectivité Internet. Deuxièmement, elle améliore la disponibilité des services critiques en évitant la congestion du réseau. Troisièmement, elle permet d'optimiser les coûts en maximisant l'utilisation de la bande passante disponible sans nécessiter d'augmentation de capacité. La limitation à 500 Ko/s par machine offre un débit suffisant pour les activités professionnelles normales tout en dissuadant les téléchargements volumineux non essentiels. L'utilisation du module `hashlimit` d'iptables est particulièrement pertinente car elle permet un contrôle granulaire basé sur l'adresse IP source, assurant que chaque poste de travail dispose de sa propre "enveloppe" de bande passante.

Le module `hashlimit` permet de créer des règles basées sur un taux de paquets ou de données, par adresse IP.

1. Application de la limitation de bande passante

Sur le pare-feu, nous allons ajouter deux règles à la chaîne `FORWARD` : une pour le trafic sortant (upload) et une pour le trafic entrant (download).

```
# Sur le pare-feu

iptables -A FORWARD -s $LAN -o $WAN_IFACE -m hashlimit --hashlimit-name lan_upload
--hashlimit-mode srcip --hashlimit-above 500kb/s -j DROP

iptables -A FORWARD -d $LAN -i $WAN_IFACE -m hashlimit --hashlimit-name
lan_download --hashlimit-mode dstip --hashlimit-above 500kb/s -j DROP
```

Justification du fonctionnement des règles :

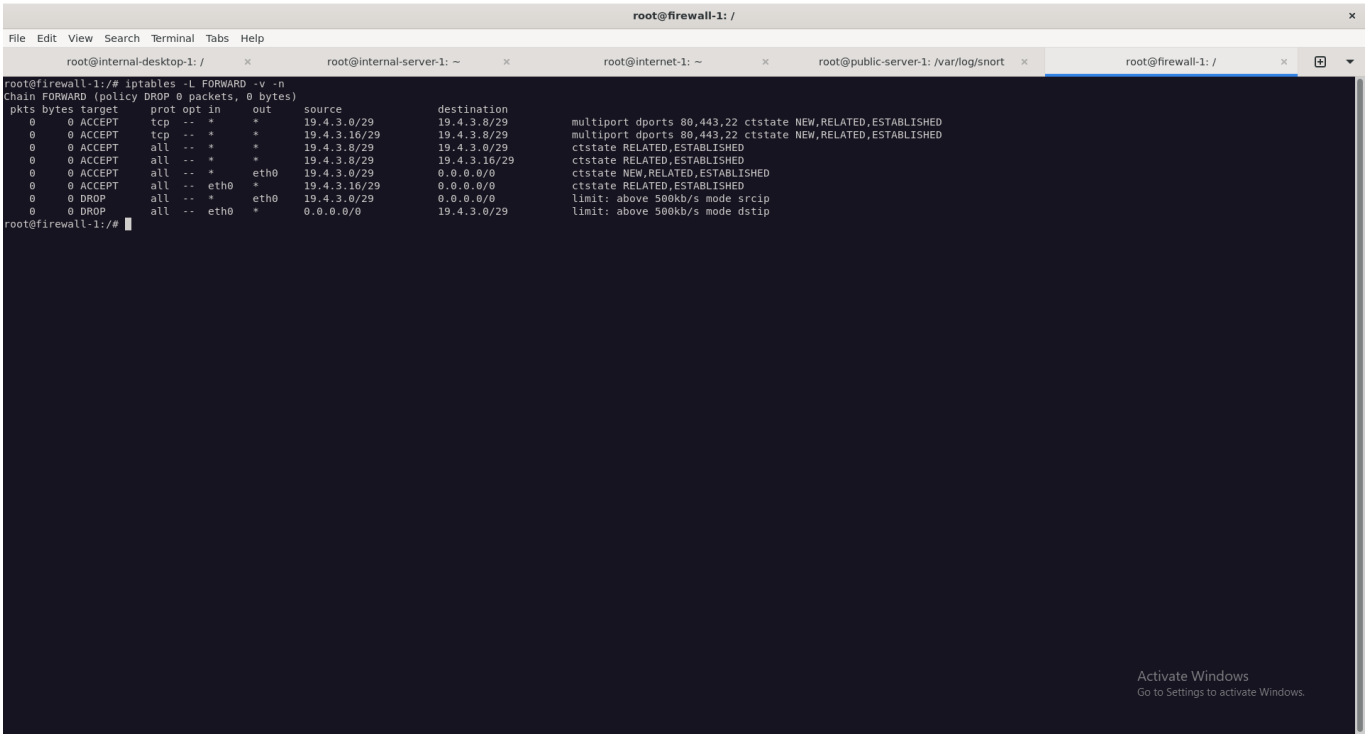
1. La première règle cible spécifiquement le trafic sortant (`-s $LAN -o $WAN_IFACE`) et utilise le module `hashlimit` pour limiter le débit. Le paramètre `--hashlimit-name lan_upload` attribue un nom à cette limite pour la distinguer dans les tables de hachage du noyau Linux. Le mode `--hashlimit-mode srcip` applique la limitation individuellement à chaque adresse IP source du LAN, garantissant ainsi l'équité entre les utilisateurs. L'action `DROP` rejette simplement les paquets dépassant le seuil de 500kb/s.
2. La seconde règle fonctionne de manière similaire mais pour le trafic entrant (`-d $LAN -i $WAN_IFACE`). Elle utilise `--hashlimit-mode dstip` pour appliquer la limite par adresse IP de destination, assurant que chaque machine du LAN est limitée indépendamment pour son trafic descendant.

Ces règles garantissent que ni l'upload ni le download ne dépassent 500 Ko/s pour chaque machine du réseau local.

2. Vérification et Test

Pour vérifier que les règles sont actives, vous pouvez lister les règles de la chaîne `FORWARD` :

```
iptables -L FORWARD -v -n
```



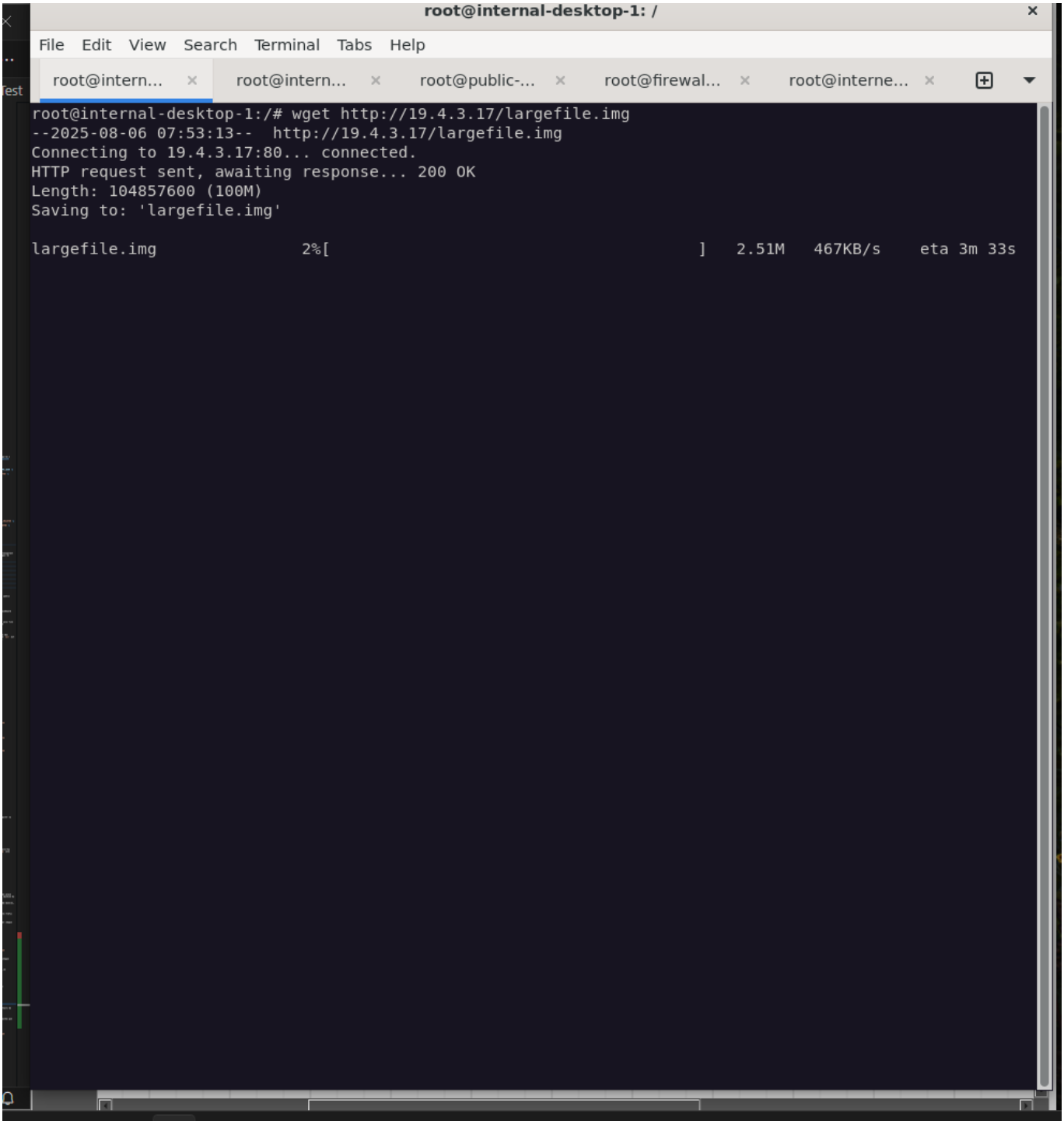
Pour tester la limitation, vous pouvez générer un fichier volumineux sur le serveur `internet` et le télécharger depuis une machine du LAN en utilisant `wget`.

```
# Sur le serveur 'internet'
dd if=/dev/zero of=/var/www/html/largefile.img bs=1M count=100

![generation du fichier volumineux](image-21.png)

# Sur 'internal-desktop'
wget http://19.4.3.17/largefile.img
```

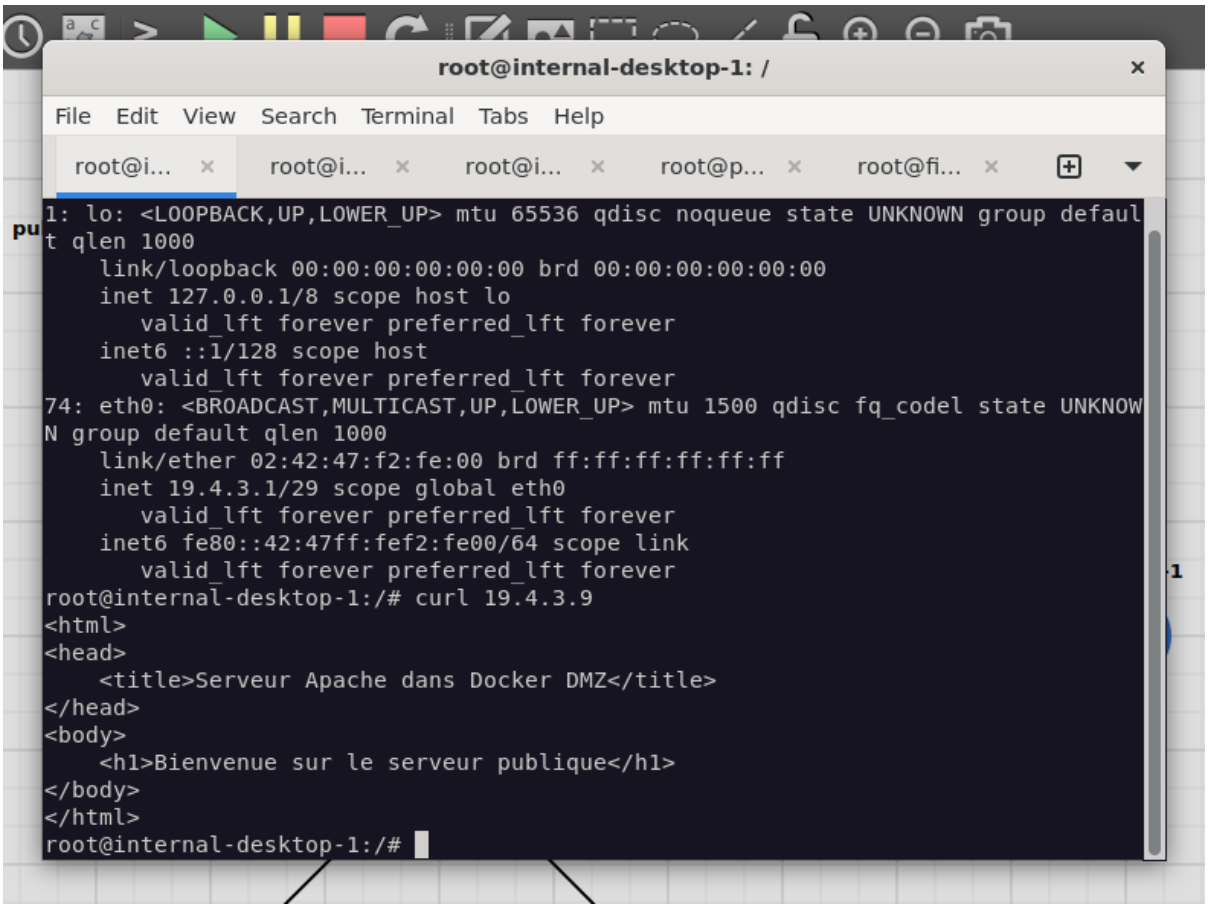
`wget` affichera la vitesse de téléchargement, qui devrait être plafonnée aux alentours de 500 KB/s.



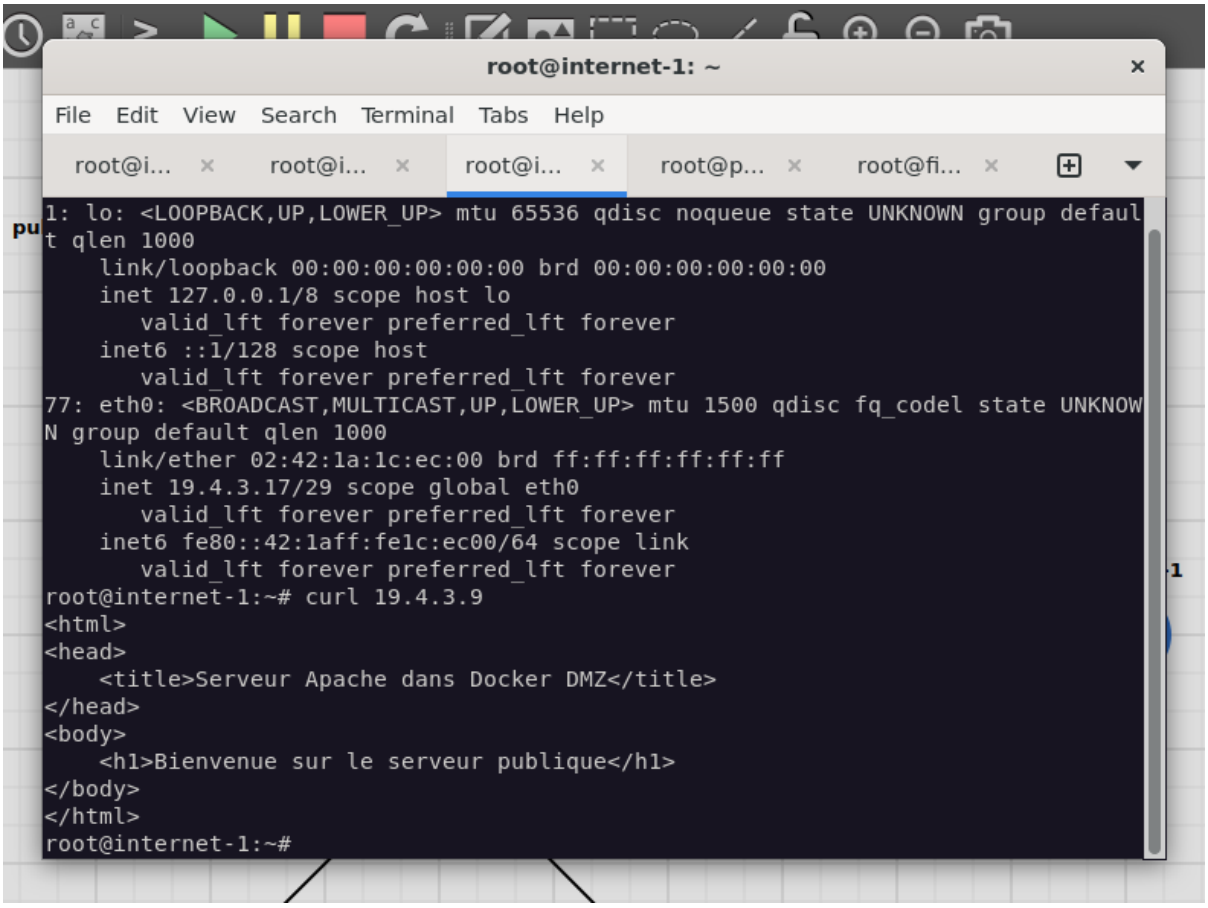
3.2. DMZ

Accessible en HTTP/HTTPS depuis WAN et LAN et **Ne peut initier aucune connexion sortante** sont déjaà realisés avec la configuration du pare-feu

- LAN -> DMZ



- WAN -> DMZ



3.3. Surveillance IDS avec Snort

Detecter et journaliser les tentatives d'attaque et de scan

Justification : L'implémentation d'un système de détection d'intrusion (IDS) comme Snort constitue une couche de défense essentielle pour notre DMZ. Contrairement au pare-feu qui se concentre sur le filtrage du trafic selon des règles préétablies, l'IDS analyse en profondeur le contenu des paquets pour identifier des signatures d'attaque connues et des comportements suspects. Ce système nous permet de détecter rapidement les tentatives de reconnaissance (scans de ports), les attaques d'injection (SQL, XSS) et d'autres vecteurs d'attaque, même si le trafic utilise des ports autorisés. La journalisation des événements fournit une traçabilité précieuse pour l'analyse forensique en cas d'incident et permet d'affiner continuellement notre politique de sécurité. Le placement de Snort directement dans la DMZ est stratégique car cette zone est particulièrement exposée aux menaces externes, étant accessible depuis Internet.

1. Configuration de base de Snort

On commence par faire un backup du fichier de configuration principal de snort

```
cp /etc/snort/snort.conf /etc/snort/snort.conf.bak
```

Nous allons configurer Snort pour qu'il détecte et journalise les tentatives d'attaque et de scan sur notre serveur DMZ (19.4.3.9).

2. Modification des variables réseau

D'abord, nous modifions les variables de réseau dans snort.conf pour cibler spécifiquement notre serveur DMZ:

```
# Dans /etc/snort/snort.conf
ipvar HOME_NET 19.4.3.9
ipvar EXTERNAL_NET !$HOME_NET
```

Commenter toutes les regles actives

```
cd /etc/snort/
sed -i '/^include \$RULE_PATH\// {/local\.rules/! s/^/#/}' snort.conf
```

3. Création de règles de détection personnalisées

Nous créons ensuite un fichier de règles local pour détecter différents types d'attaques:

```
# Créer le fichier local.rules
cat > /etc/snort/rules/local.rules << 'EOF'
```

```
# ==== SCANS DE PORT ====
alert tcp any any -> $HOME_NET any (msg:"[SCAN] TCP SYN scan détecté"; flags:S,12;
threshold:type threshold, track by_src, count 5, seconds 60; classtype:attempted-
recon; sid:2000001; rev:1;)

alert tcp any any -> $HOME_NET any (msg:"[SCAN] TCP Connect scan détecté";
flags:S; threshold:type threshold, track by_src, count 10, seconds 60;
classtype:attempted-recon; sid:2000002; rev:1;)

alert udp any any -> $HOME_NET any (msg:"[SCAN] UDP scan détecté"; threshold:type
threshold, track by_src, count 15, seconds 60; classtype:attempted-recon;
sid:2000003; rev:1;)

# ==== ATTAQUES DoS ====
alert icmp any any -> $HOME_NET any (msg:"[DoS] Attaque ICMP flood détectée";
threshold:type threshold, track by_src, count 30, seconds 10; classtype:attempted-
dos; sid:2000010; rev:1;)

alert tcp any any -> $HOME_NET any (msg:"[DoS] Attaque SYN flood détectée";
flags:S,12; flow:stateless; threshold:type threshold, track by_src, count 50,
seconds 10; classtype:attempted-dos; sid:2000011; rev:1;)

# ==== ATTAQUES WEB ====
alert tcp any any -> $HOME_NET 80 (msg:"[WEB] Possible injection SQL détectée";
content:"UNION SELECT"; nocase; classtype:web-application-attack; sid:2000020;
rev:1;)

alert tcp any any -> $HOME_NET 80 (msg:"[WEB] Possible attaque XSS détectée";
content:"<script>"; nocase; classtype:web-application-attack; sid:2000022; rev:1;)
EOF
```

4. Configuration de la journalisation

Pour assurer un suivi complet des attaques détectées, nous configurons plusieurs formats de journalisation dans snort.conf:

```
# Dans /etc/snort/snort.conf
output log_tcpdump: /var/log/snort/tcpdump.log
```

5. Démarrage de Snort avec la nouvelle configuration

Enfin, nous démarrons Snort avec la configuration mise à jour:

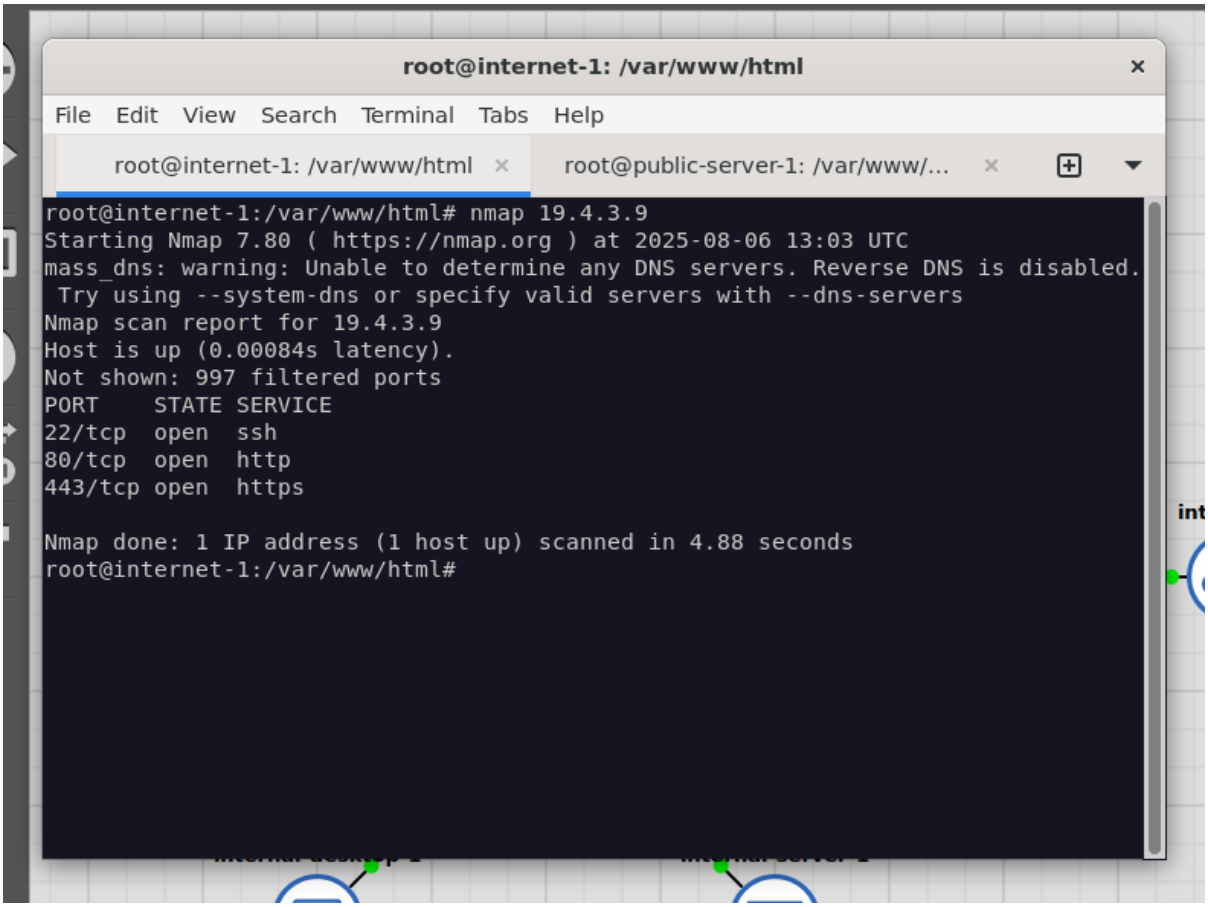
```
# Créer le répertoire pour les logs
mkdir -p /var/log/snort/

chown -R snort:snort /var/log/snort/
```

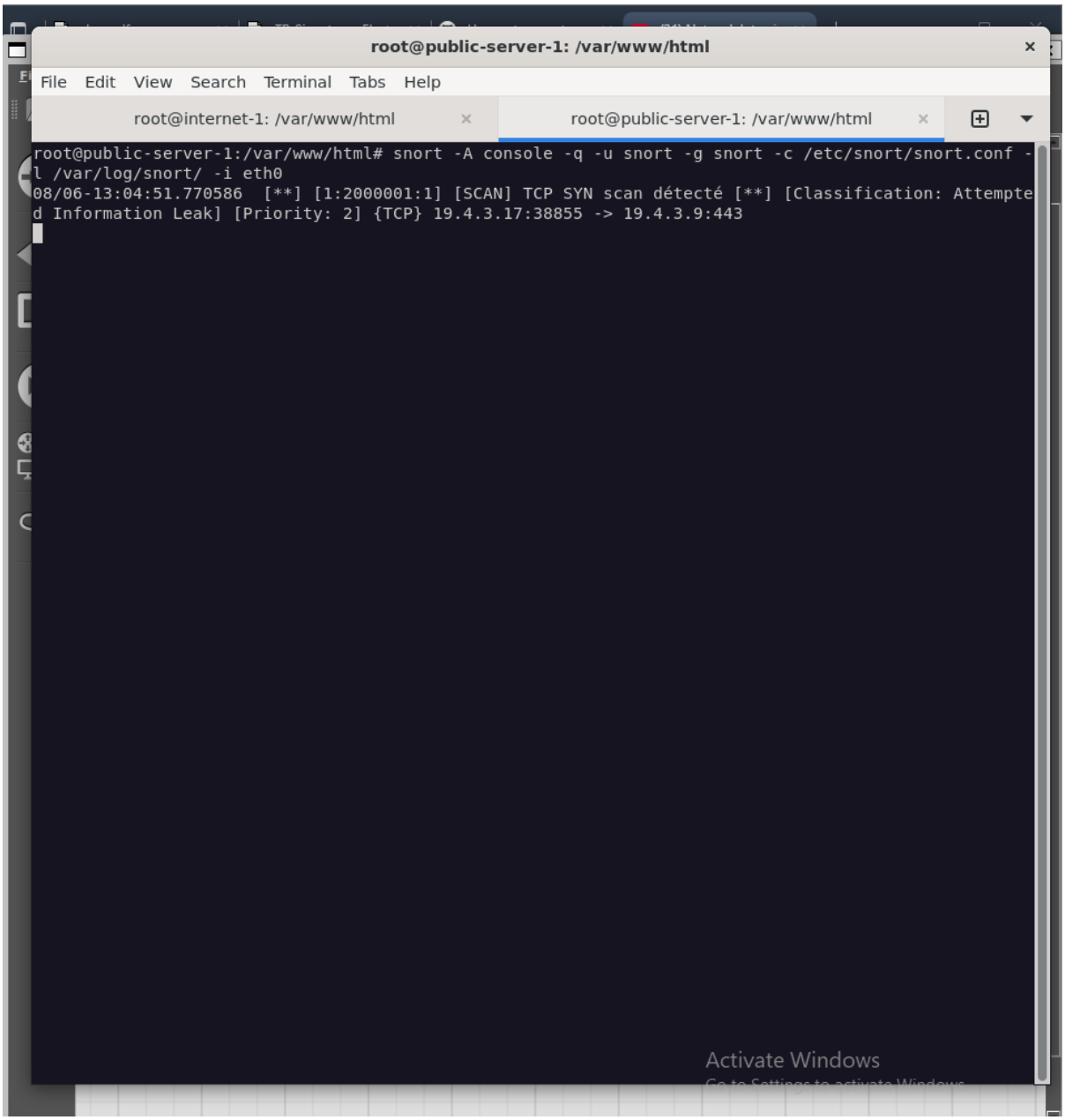
```
# Verifier si les syntax sont correctes
snort -T -c /etc/snort/snort.conf

service snort restart

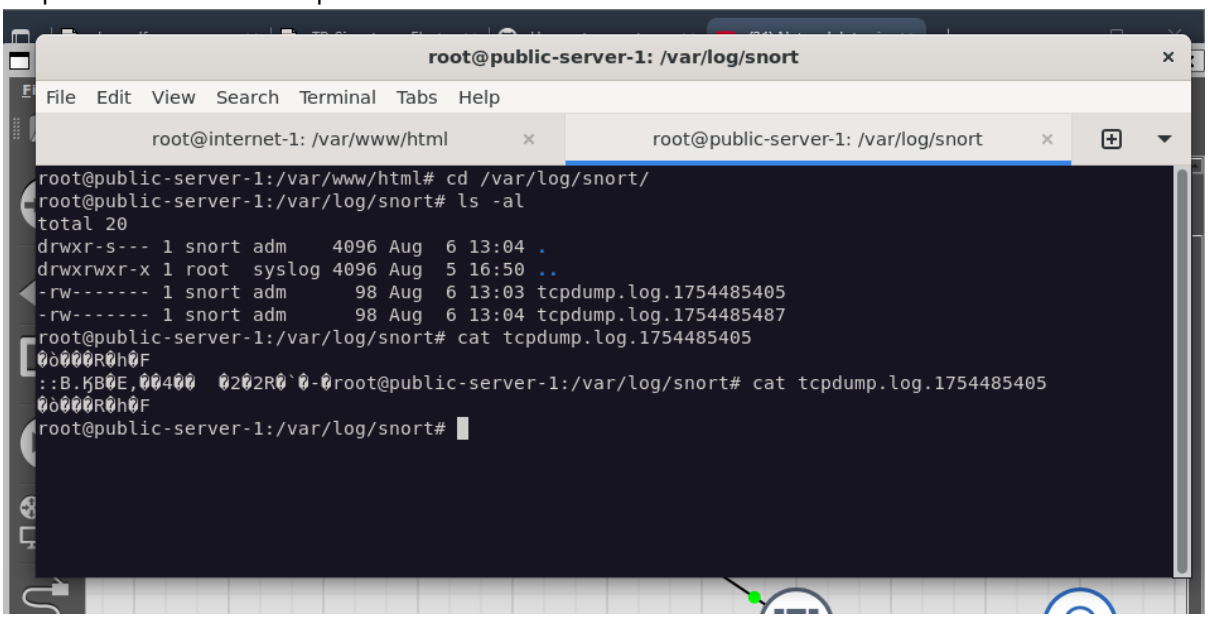
# Demarrer snort
# snort -A console -q -u snort -g snort -c /etc/snort/snort.conf -l
/var/log/snort/ -i eth0
snort -A console -q -u snort -g snort -c /etc/snort/snort.conf -l /var/log/snort/
-i eth0
```

- nmap depuis internet vers la DMZ
  - 

- detection de nmap par snort dans la DMZ



- log snort pour les scans de nmap



Résultats des tests

Cette section présente une synthèse des différents tests effectués pour valider le bon fonctionnement de notre architecture DMZ et des mécanismes de sécurité mis en place.

Connectivité et isolation des réseaux

Test	Résultat	Acteurs impliqués	Commande utilisée	Observation
LAN → DMZ (HTTP/HTTPS)	Réussi	Depuis `internal-desktop` vers `public-server`	`curl http://19.4.3.9` `curl -k https://19.4.3.9`	Le trafic est correctement autorisé depuis le LAN vers les services web de la DMZ
WAN → DMZ (HTTP/HTTPS)	Réussi	Depuis `internet` vers `public-server`	`curl http://19.4.3.9` `curl -k https://19.4.3.9`	Le trafic est correctement autorisé depuis le WAN vers les services web de la DMZ
LAN → WAN	Réussi	Depuis `internal-desktop` vers `internet`	`ping 19.4.3.17`	Le trafic sortant du LAN est correctement masqué par NAT
WAN → LAN	Bloqué	Depuis `internet` vers `internal-server`	`curl http://19.4.3.2`	Aucun accès direct n'est possible depuis le WAN vers le LAN, comme prévu
DMZ → LAN	Bloqué	Depuis `public-server` vers `internal-server`	`ping 19.4.3.2`	La DMZ ne peut pas initier de connexion vers le LAN, assurant une bonne isolation

Filtrage de contenu

Test	Résultat	Acteurs impliqués	Commande utilisée	Observation
Accès aux sites pornographiques	Bloqué	Depuis `internal-desktop` via `firewall` (SquidGuard)	`curl http://pornhub.com`	Le filtrage SquidGuard bloque efficacement l'accès aux sites pornographiques
Accès aux réseaux sociaux (heures de travail)	Bloqué	Configuration sur `firewall` puis test depuis `internal-desktop`	`date -s "09:30:00"` `curl http://facebook.com`	L'accès est bloqué pendant les heures de travail définies

Test	Résultat	Acteurs impliqués	Commande utilisée	Observation
Accès aux réseaux sociaux (hors heures)	Autorisé	Configuration sur `firewall` puis test depuis `internal-desktop`	`date -s "13:30:00"` `curl http://facebook.com`	L'accès est correctement autorisé en dehors des heures de travail

Qualité de service et limitation de bande passante

Test	Résultat	Acteurs impliqués	Commandes utilisées	Observation

Téléchargement de fichier volumineux	Limité	Depuis `internal-desktop` vers `internet` à travers les règles QoS du `firewall`	Sur le serveur WAN (`internet`) :
			`dd if=/dev/zero of=/var/www/html/largefile.img bs=1M count=100`
			
			Sur le client LAN (`internal-desktop`) :
			`wget http://19.4.3.17/largefile.img`
				La vitesse est effectivement plafonnée à environ 500 KB/s

Détection d'intrusion

Test	Résultat	Acteurs impliqués	Commandes utilisées	Observation

Scan de ports depuis le WAN	Détecté	Attaque depuis `internet`, détection par `snort` sur `public-server`	Sur `internet` :
			`nmap -sS 19.4.3.9`
			
			Sur `public-server` pour vérifier les logs :
			`cat /var/log/snort/alert.fast`
				Snort détecte et journalise correctement les tentatives de scan de ports

Simulation d'attaques web	Détecté	Attaque depuis `internet`, détection par `snort` sur `public-server`	Sur `internet` :
			`curl "http://19.4.3.9/?id=1 UNION SELECT username,password FROM users"`
			`curl "http://19.4.3.9/?data=<script>alert('XSS')</script>"`
				Les requêtes suspectes contenant des motifs d'attaque sont identifiées

Ces tests confirment que notre architecture DMZ répond aux exigences de sécurité définies dans le cahier des charges. L'isolation des différentes zones réseau est effective, le filtrage de contenu fonctionne correctement selon les politiques établies, et les mécanismes de détection d'intrusion sont opérationnels.

Analyse et conclusion

Notre mise en œuvre d'une architecture DMZ via GNS3 et Docker a permis de créer un environnement réseau sécurisé qui répond aux objectifs initiaux. Cette section présente une analyse des résultats obtenus et les conclusions tirées de ce travail pratique.

Réalisation des objectifs

1. **Isolation des réseaux** : La DMZ a été correctement isolée du LAN interne, permettant d'héberger des services accessibles depuis l'extérieur sans compromettre la sécurité du réseau interne.

2. **Filtrage du trafic** : Le pare-feu a été configuré pour filtrer efficacement le trafic entre les différentes zones (WAN, DMZ, LAN) selon les règles établies. Les tests ont confirmé que seuls les services autorisés (HTTP, HTTPS, SSH) sont accessibles depuis le LAN et le WAN vers la DMZ.

3. **Protection contre les attaques** : L'intégration de Snort a démontré la capacité à détecter et journaliser diverses tentatives d'attaque et de scan, comme montré lors des tests avec nmap.

4. **Contrôle d'accès au contenu** : Le système de filtrage avec Squid et SquidGuard a permis de bloquer efficacement les réseaux sociaux pendant les heures de travail et les sites pornographiques .

5. **Qualité de service** : La limitation de bande passante à 500 KB/s pour chaque machine du LAN assure une distribution équitable des ressources réseau.

Difficultés rencontrées

1. **Configuration de SquidGuard** : La mise en place du filtrage de contenu a nécessité une attention particulière aux permissions des fichiers et à la syntaxe du fichier de configuration.

2. **Gestion des règles iptables** : L'élaboration d'un ensemble cohérent de règles de pare-feu a demandé une compréhension approfondie des mécanismes de filtrage et de NAT.

3. **Intégration de Snort** : La configuration des règles de détection pour cibler spécifiquement notre environnement a requis plusieurs ajustements.

4. **Absence d'accès Internet** : Dans notre environnement de simulation, nous n'avons pas pu avoir un accès réel à Internet, ce qui a limité certains tests notamment pour le filtrage de contenu et la résolution DNS. Nous avons dû simuler ces aspects en utilisant des entrées DNS locales et des contenus hébergés dans notre propre infrastructure.

Conclusion

Ce travail pratique nous a permis d'appliquer concrètement les concepts théoriques de sécurité réseau à travers la mise en place d'une DMZ fonctionnelle. La combinaison de GNS3 et Docker s'est révélée être un choix pertinent, offrant la flexibilité nécessaire pour simuler une infrastructure réseau complexe.

Les compétences développées lors de ce projet incluent la configuration avancée de pare-feu, la mise en œuvre de systèmes de filtrage de contenu, et l'utilisation d'outils de détection d'intrusion.

En conclusion, malgré quelques difficultés techniques, l'objectif principal de créer une architecture DMZ sécurisée a été atteint avec succès. Les tests effectués ont validé le bon fonctionnement de l'ensemble des

mécanismes de sécurité mis en place, démontrant ainsi la robustesse de notre solution.